BỘ GIÁO DỤC VÀ ĐÀO TẠO

TRƯỜNG ĐẠI HỌC CÔNG NGHỆ TP. HCM

ĐỒ ÁN CƠ SỞ

Thiết kế và đánh giá hệ thống bảo mật mạng doanh nghiệp sử dụng Firewall (pfSense).

Giảng viên hướng dẫn: TS.Văn Thiên Hoàng

Sinh viên thực hiện	Lớp	MSSV
1. Trần Tăng Trường Thịnh	23DATA1	2387701939

TP. Hồ Chí Minh, 2026

BỘ GIÁO DỤC VÀ ĐÀO TẠO

TRƯỜNG ĐẠI HỌC CÔNG NGHỆ TP. HCM

ĐỒ ÁN CƠ SỞ

Thiết kế và đánh giá hệ thống bảo mật mạng doanh nghiệp sử dụng Firewall (pfSense).

Giảng viên hướng dẫn: TS.Văn Thiên Hoàng

Sinh viên thực hiện	Lớp	MSSV
1. Trần Tăng Trường Thịnh	23DATA1	2387701939

TP. Hồ Chí Minh, 2026

LỜI MỞ ĐẦU

Trong thời đại chuyển đổi số hiện nay, hệ thống mạng máy tính đóng vai trò quan trọng trong hoạt động của các doanh nghiệp. Các hệ thống này không chỉ hỗ trợ trao đổi thông tin mà còn là nền tảng cho các dịch vụ kinh doanh, lưu trữ dữ liệu và quản lý vận hành. Tuy nhiên, cùng với sự phát triển của công nghệ, các mối đe dọa an ninh mạng cũng ngày càng gia tăng cả về số lượng lẫn mức độ tinh vi.

Thực tế cho thấy, các cuộc tấn công như quét cổng (port scanning), truy cập trái phép và khai thác lỗ hổng dịch vụ diễn ra phổ biến trên Internet. Nhiều hệ thống doanh nghiệp, đặc biệt là quy mô vừa và nhỏ, chưa được cấu hình bảo mật tối ưu, dẫn đến nguy cơ bị xâm nhập và rò rỉ dữ liệu. Điều này đặt ra yêu cầu cấp thiết trong việc xây dựng các giải pháp bảo mật mạng hiệu quả và phù hợp thực tế.

Trong các giải pháp hiện nay, Firewall là thành phần quan trọng giúp kiểm soát và lọc lưu lượng mạng dựa trên các quy tắc thiết lập, từ đó ngăn chặn truy cập trái phép. Đặc biệt, firewall mã nguồn mở như pfSense được sử dụng rộng rãi nhờ tính linh hoạt và chi phí thấp.

Xuất phát từ đó, đề tài "Thiết kế và đánh giá hệ thống bảo mật mạng doanh nghiệp sử dụng Firewall (pfSense)" được thực hiện nhằm nghiên cứu, triển khai và đánh giá hiệu quả của firewall. Hệ thống được thiết kế theo mô hình WAN, LAN và DMZ, sử dụng các cơ chế như NAT, ACL, Port Filtering và chính sách Default Deny để kiểm soát truy cập. Quá trình thực nghiệm được thực hiện bằng các kịch bản như quét cổng với Nmap và kiểm tra truy cập dịch vụ, từ đó so sánh hiệu quả giữa các cấu hình firewall khác nhau nhằm đánh giá khả năng giảm thiểu rủi ro tấn công.

Do kiến thức và kinh nghiệm còn hạn chế, báo cáo không tránh khỏi những thiếu sót. Em rất mong nhận được sự góp ý của thầy để nội dung được hoàn thiện hơn.

LỜI CẢM ƠN

Trong quá trình thực hiện đồ án cơ sở này, em đã nhận được sự hướng dẫn và hỗ trợ quý báu từ thầy cô, bạn bè và gia đình.

Trước hết, em xin bày tỏ lòng biết ơn sâu sắc đến thầy TS. Văn Thiên Hoàng – giảng viên hướng dẫn, người đã tận tình chỉ bảo, định hướng và góp ý trong suốt quá trình thực hiện đề tài. Những ý kiến đóng góp của thầy đã giúp em hoàn thiện nội dung đồ án cũng như hiểu rõ hơn về cách tiếp cận và giải quyết một bài toán trong lĩnh vực bảo mật mạng.

Em xin chân thành cảm ơn quý thầy cô trong Viện Công nghệ Thông tin – Trường Đại học Công nghệ TP. Hồ Chí Minh đã trang bị cho em những kiến thức nền tảng quan trọng trong suốt quá trình học tập. Đây chính là cơ sở giúp em có thể thực hiện đề tài "Thiết kế và đánh giá hệ thống bảo mật mạng doanh nghiệp sử dụng Firewall (pfSense)".

Bên cạnh đó, em cũng xin cảm ơn gia đình và bạn bè đã luôn động viên, hỗ trợ và tạo điều kiện thuận lợi để em hoàn thành đồ án đúng tiến độ.

Mặc dù đã cố gắng hết sức, nhưng do kiến thức và kinh nghiệm còn hạn chế, báo cáo không tránh khỏi những thiếu sót. Em rất mong nhận được sự góp ý của thầy cô để bài báo cáo được hoàn thiện hơn.

Em xin chân thành cảm ơn!

Sinh viên thực hiện

Trần Tăng Trường Thịnh

NHIỆM VỤ ĐỒ ÁN

- Nghiên cứu cơ sở lý thuyết về bảo mật mạng và firewall, bao gồm các khái niệm, phân loại và các cơ chế hoạt động như NAT, Port Filtering, Access Control List (ACL).

- Thiết kế mô hình mạng doanh nghiệp mô phỏng gồm các thành phần chính như WAN, LAN và DMZ, đảm bảo phản ánh đúng kiến trúc mạng thực tế.

- Xây dựng môi trường thực nghiệm bằng máy ảo (VMware), cài đặt và cấu hình hệ thống firewall sử dụng pfSense.

  Thiết lập firewall theo nguyên tắc Default Deny, chỉ cho phép các dịch vụ cần thiết nhằm kiểm soát và đảm bảo an toàn lưu lượng mạng

- Thực hiện các kịch bản kiểm thử bảo mật bằng các công cụ như Nmap và Ping để đánh giá khả năng phát hiện và ngăn chặn tấn công của hệ thống.

- Tiến hành thử nghiệm trong nhiều trường hợp khác nhau (không có firewall, firewall có tích hợp IDS/IPS) nhằm so sánh hiệu quả bảo mật.

- Thu thập dữ liệu thực nghiệm, bao gồm số lượng port mở, trạng thái truy cập và log từ firewall để phục vụ quá trình phân tích.

- Phân tích, đánh giá kết quả thực nghiệm dựa trên các tiêu chí như khả năng chặn truy cập trái phép, mức độ ẩn port và hiệu quả ghi log.

- Đề xuất nhận xét và đánh giá tổng thể về hiệu quả của firewall trong việc bảo vệ hệ thống mạng doanh nghiệp.

- Hoàn thiện báo cáo đồ án theo đúng quy định của Viện Công nghệ Thông tin – HUTECH.

NHẬN XÉT CỦA GIẢNG VIÊN

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

MỤC LỤC

LỜI MỞ ĐẦU **3**
LỜI CẢM ƠN **4**
NHIỆM VỤ ĐỒ ÁN **5**
NHẬN XÉT CỦA GIẢNG VIÊN **6**
MỤC LỤC **7**
CHƯƠNG 1: TỔNG QUAN **10**
1.1. Giới thiệu đề tài ***10***
1.1.1. Bối cảnh an toàn mạng doanh nghiệp 10
1.1.2. Vai trò của firewall trong kiến trúc bảo mật 11
1.2. Tính cấp thiết và lý do chọn đề tài ***12***
1.3. Mục tiêu nghiên cứu ***13***
1.4. Đối tượng và phạm vi nghiên cứu ***14***
1.4.1. Đối tượng nghiên cứu 14
1.4.2. Phạm vi nghiên cứu 14
1.5. Phương pháp nghiên cứu ***15***
1.5.1. Phương pháp lý thuyết 15
1.5.2. Phương pháp thực nghiệm 16
1.6. Ý nghĩa khoa học và thực tiễn ***17***
1.7. Bố cục báo cáo dự kiến: ***17***
CHƯƠNG 2: CƠ SỞ LÝ THUYẾT **19**
2.1. Tổng quan về bảo mật mạng doanh nghiệp ***19***
2.1.1. Kiến trúc mạng doanh nghiệp 19
2.1.2. Mô hình phòng thủ nhiều lớp (Defense in Depth) 20
2.2. Firewall và các nguyên lý hoạt động ***21***
2.2.1. Phân loại Firewall 21
2.2.2. Cơ chế lọc gói và kiểm soát truy cập 22
2.2.3. NAT và quản lý kết nối 23
2.3. Tổng quan về pfSense ***24***
2.3.1. Kiến trúc và thành phần 24
2.3.2. Các chức năng chính (Firewall, NAT, VPN, VLAN) 25
2.3.3. Ưu điểm và hạn chế 25
2.4. Các mối đe dọa mạng phổ biến ***26***
2.4.1. Tấn công quét cổng (Port Scanning) 26

2.4.2. Tấn công brute-force 27
2.4.3. Tấn công từ chối dịch vụ (DoS/DDoS) 27
2.5. Tiêu chí đánh giá hệ thống bảo mật 28
2.6. Kết luận chương 28
CHƯƠNG 3. THIẾT KẾ HỆ THỐNG BẢO MẬT MẠNG 29
3.1. Tổng quan mô hình đề xuất 29
3.2. Thiết kế kiến trúc mạng 29
3.2.1. Phân vùng mạng (WAN, LAN, DMZ) 29
3.2.2. Sơ đồ kiến trúc hệ thống 30
3.3. Thiết kế hệ thống firewall pfSense 31
3.3.1. Cài đặt và cấu hình cơ bản 31
3.3.2. Thiết lập rule firewall 31
3.3.3. Cấu hình NAT và Port Forwarding 32
3.4. Triển khai các cơ chế bảo mật 32
3.4.1. Kiểm soát truy cập 32
3.4.2. Phân đoạn mạng (Network Segmentation) 32
3.5. Xây dựng chính sách bảo mật 33
3.6. Kết luận chương 33
CHƯƠNG 4. TRIỂN KHAI THỰC NGHIỆM VÀ ĐÁNH GIÁ 34
4.1. Môi trường thực nghiệm 34
4.1.1. Hạ tầng ảo hóa (VMware/VirtualBox) 34
4.1.2. Cấu hình hệ thống 36
4.2. Kịch bản tấn công mô phỏng 43
4.2.1. Quét cổng (Nmap) 43
4.2.2. Brute-force SSH 43
4.3. Kết quả kiểm thử trước khi triển khai IDS/IPS trên pfSense 44
4.3.1. Kết quả quét cổng (Port Scanning) 44
4.3.2. Kết quả brute-force SSH 45
4.4. Kết quả kiểm thử sau khi kích hoạt IDS/IPS trên pfSense 47
4.4.1. Kết quả quét cổng (Port Scanning) sau khi triển khai Snort IDS/IPS 47
4.4.2. Kết quả brute-force SSH sau khi triển khai Suricata 49
4.4.3. Bảng so sánh kết quả trước và sau khi kích hoạt IDS/IPS 50
4.5. Đánh giá hiệu quả hệ thống 51
4.5.1. Khả năng phát hiện và ngăn chặn 51
4.5.2. Tính ổn định hệ thống 51
4.5.3. Ảnh hưởng đến hiệu năng mạng 51

4.6. Thảo luận kết quả *52*
4.7. Kết luận chương *52*
CHƯƠNG 5. KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN **53**
5.1. Kết luận *53*
5.2. Đóng góp của đề tài *53*
5.3. Hạn chế *53*
5.4. Hướng phát triển trong tương lai *53*
Tài Liệu Tham Khảo **54**

CHƯƠNG 1: TỔNG QUAN

1.1. Giới thiệu đề tài

Trong môi trường doanh nghiệp hiện đại, hệ thống mạng đóng vai trò quan trọng trong việc kết nối, trao đổi dữ liệu và vận hành các dịch vụ. Tuy nhiên, cùng với sự phát triển của công nghệ, các nguy cơ mất an toàn thông tin ngày càng gia tăng. Điều này đặt ra yêu cầu cần có các giải pháp bảo mật hiệu quả nhằm kiểm soát truy cập và giảm thiểu rủi ro trong hệ thống mạng doanh nghiệp.

Bài toán đặt ra là xây dựng một hệ thống mạng có khả năng kiểm soát lưu lượng truy cập, ngăn chặn truy cập trái phép nhưng vẫn đảm bảo các dịch vụ cần thiết hoạt động ổn định. Để giải quyết vấn đề này, đề tài sử dụng firewall pfSense với các cơ chế như NAT, Port Filtering và Access Control List (ACL) nhằm kiểm soát và phân tách lưu lượng mạng.

Hệ thống được thiết kế theo mô hình WAN, LAN và DMZ, trong đó firewall đóng vai trò trung tâm trong việc kiểm soát lưu lượng giữa các vùng. Các chính sách như Default Deny được áp dụng nhằm tăng cường bảo mật. Bên cạnh đó, đề tài tiến hành thực nghiệm bằng công cụ Nmap để kiểm tra trạng thái port và khả năng truy cập hệ thống, từ đó đánh giá hiệu quả của các phương án cấu hình firewall.

1.1.1. Bối cảnh an toàn mạng doanh nghiệp

Trong những năm gần đây, an toàn thông tin trở thành một trong những vấn đề trọng yếu đối với các tổ chức và doanh nghiệp. Theo báo cáo OWASP Top 10 (2021) [1], các lỗ hổng bảo mật và hình thức tấn công mạng vẫn liên tục gia tang và ngày càng tinh vi.

Các hoạt động như quét cổng (port scanning), dò tìm dịch vụ (service enumeration) và khai thác lỗ hổng đang diễn ra phổ biến trên Internet. Đặc biệt, nhiều hệ thống mạng doanh nghiệp chưa được cấu hình bảo mật đầy đủ, dẫn đến nguy cơ bị xâm nhập, đánh cắp dữ liệu hoặc gián đoạn dịch vụ.

Thực tế này cho thấy nhu cầu cấp thiết trong việc xây dựng các giải pháp bảo mật mạng hiệu quả nhằm đảm bảo tính toàn vẹn, bảo mật và sẵn sàng của hệ thống thông tin.

1.1.2. Vai trò của firewall trong kiến trúc bảo mật

Firewall là một trong những thành phần cốt lõi trong kiến trúc bảo mật mạng, có chức năng giám sát và kiểm soát lưu lượng truy cập giữa các vùng mạng khác nhau dựa trên các chính sách đã được thiết lập.

Trong mô hình mạng doanh nghiệp, firewall thường được triển khai tại các điểm giao tiếp như giữa WAN và LAN hoặc giữa LAN và DMZ nhằm phân tách và bảo vệ các vùng mạng quan trọng. Các cơ chế như NAT giúp che giấu địa chỉ IP nội bộ, Port Filtering cho phép kiểm soát truy cập theo cổng dịch vụ, trong khi Access Control List (ACL) giúp định nghĩa các quy tắc cho phép hoặc từ chối lưu lượng.

Việc áp dụng chính sách mặc định "Default Deny" giúp ngăn chặn toàn bộ các truy cập không hợp lệ, chỉ cho phép những lưu lượng đã được xác định rõ ràng. Nhờ đó, firewall góp phần quan trọng trong việc giảm thiểu bề mặt tấn công và nâng cao mức độ an toàn cho hệ thống mạng doanh nghiệp.

1.2. Tính cấp thiết và lý do chọn đề tài

Trong bối cảnh chuyển đổi số, hệ thống mạng và các ứng dụng CNTT ngày càng trở thành nền tảng cốt lõi của doanh nghiệp. Tuy nhiên, sự phát triển này cũng kéo theo nhiều mối đe dọa an ninh mạng như tấn công xâm nhập, đánh cắp dữ liệu, khai thác lỗ hổng và tấn công từ chối dịch vụ, gây ảnh hưởng đến tài chính, uy tín và hoạt động của tổ chức.

Thực tế cho thấy nhiều hệ thống vẫn tồn tại lỗ hổng do thiết kế chưa tối ưu hoặc cấu hình thiếu an toàn, đặc biệt ở các doanh nghiệp vừa và nhỏ. Vì vậy, việc xây dựng một hệ thống mạng an toàn, ổn định và có khả năng phòng chống tấn công là yêu cầu cần thiết.

Từ đó, đề tài được thực hiện nhằm:

- Nghiên cứu các nguy cơ mất an toàn thông tin trong hệ thống mạng
- Đề xuất và triển khai mô hình mạng có tính bảo mật cao
- Áp dụng các kỹ thuật nhằm nâng cao khả năng phòng thủ hệ thống

Mục tiêu của đề tài là xây dựng và đánh giá hệ thống bảo mật mạng doanh nghiệp sử dụng firewall để kiểm soát truy cập và giảm thiểu nguy cơ tấn công. Nội dung tập trung vào các cơ chế như NAT, Port Filtering, Access Control List (ACL) và chính sách kiểm soát truy cập.

Đề tài thiết kế mô hình mạng gồm WAN, LAN và DMZ, triển khai firewall pfSense để kiểm soát lưu lượng giữa các vùng. Đồng thời, thực hiện kiểm thử bằng các công cụ như Nmap và Ping nhằm đánh giá khả năng phát hiện và ngăn chặn truy cập trái phép.

Kết quả được so sánh giữa các trường hợp không có firewall, firewall cơ bản và firewall tối ưu, từ đó đánh giá hiệu quả của hệ thống và đề xuất hướng triển khai phù hợp trong thực tế.

1.3. Mục tiêu nghiên cứu

Mục tiêu của đề tài là xây dựng và đánh giá một hệ thống bảo mật mạng doanh nghiệp sử dụng firewall nhằm nâng cao khả năng kiểm soát truy cập và giảm thiểu các nguy cơ tấn công từ bên ngoài.

Cụ thể, đề tài hướng đến các mục tiêu sau:

- Nghiên cứu các mối đe dọa an ninh mạng phổ biến và các lỗ hổng trong hệ thống mạng doanh nghiệp

- Tìm hiểu cơ chế hoạt động của firewall và các kỹ thuật liên quan như NAT, Port Filtering và Access Control List (ACL)

- Thiết kế mô hình mạng doanh nghiệp gồm các vùng WAN, LAN và DMZ

- Triển khai và cấu hình firewall pfSense để kiểm soát lưu lượng mạng

- Thực hiện kiểm thử bảo mật bằng các công cụ như Nmap nhằm đánh giá khả năng phát hiện và ngăn chặn truy cập trái phép

- So sánh và đánh giá hiệu quả giữa các phương án cấu hình firewall khác nhau

1.4. Đối tượng và phạm vi nghiên cứu

1.4.1. Đối tượng nghiên cứu

Đối tượng nghiên cứu của đề tài là hệ thống bảo mật mạng doanh nghiệp sử dụng firewall, cụ thể là firewall pfSense. Trọng tâm nghiên cứu tập trung vào các cơ chế kiểm soát và bảo vệ hệ thống mạng thông qua việc quản lý lưu lượng truy cập giữa các vùng mạng.

Hệ thống được xây dựng theo mô hình gồm các thành phần WAN, LAN và DMZ, trong đó firewall đóng vai trò trung tâm trong việc kiểm soát và phân tách lưu lượng. Các cơ chế bảo mật chính được nghiên cứu bao gồm NAT (Network Address Translation), Port Filtering, Access Control List (ACL) và các chính sách kiểm soát truy cập như Default Deny.

1.4.2. Phạm vi nghiên cứu

Phạm vi nghiên cứu của đề tài được giới hạn trong việc thiết kế, triển khai và đánh giá hệ thống bảo mật mạng doanh nghiệp sử dụng firewall pfSense trong môi trường mô phỏng trên nền tảng máy ảo (VMware).

Đề tài tập trung nghiên cứu các cơ chế bảo mật cơ bản như NAT, Port Filtering, Access Control List (ACL) và chính sách Default Deny trong việc kiểm soát lưu lượng giữa các vùng WAN, LAN và DMZ. Các kiểm thử chủ yếu bao gồm quét cổng và kiểm tra truy cập dịch vụ.

Đề tài tập trung nghiên cứu firewall pfSense và thử nghiệm cơ bản với IDS/IPS Snort nhằm tăng cường khả năng phát hiện và ngăn chặn tấn công.

1.5. Phương pháp nghiên cứu

Đề tài được thực hiện dựa trên sự kết hợp giữa phương pháp nghiên cứu lý thuyết và phương pháp thực nghiệm nhằm đảm bảo tính khoa học và khả năng ứng dụng thực tiễn của hệ thống.

1.5.1. Phương pháp lý thuyết

Phương pháp nghiên cứu lý thuyết được sử dụng để xây dựng nền tảng kiến thức cho đề tài. Cụ thể:

- Thu thập và nghiên cứu các tài liệu liên quan đến:
  - Firewall và cơ chế hoạt động
  - NAT (Network Address Translation)
  - Port Filtering
  - Access Control List (ACL)

- Tham khảo các tiêu chuẩn và tài liệu uy tín như:
  - OWASP
  - NIST
  - Tài liệu chính thức của pfSense

- Phân tích nguyên lý hoạt động của các mô hình mạng:
  - WAN, LAN, DMZ

Thông qua đó, đề tài xây dựng cơ sở lý thuyết vững chắc phục vụ cho quá trình triển khai và đánh giá hệ thống.

1.5.2. Phương pháp thực nghiệm

Phương pháp thực nghiệm được sử dụng nhằm kiểm chứng các nội dung lý thuyết đã nghiên cứu thông qua việc triển khai và đánh giá hệ thống thực tế. Cụ thể:

- Xây dựng mô hình mạng trong môi trường ảo hóa VMware, bao gồm:
  - WAN, LAN và DMZ

- Cài đặt và cấu hình firewall pfSense để:
  - Kiểm soát lưu lượng giữa các vùng mạng
  - Thiết lập các rule truy cập và NAT

- Sử dụng các công cụ kiểm tra như:
  - Nmap (quét cổng, kiểm tra dịch vụ)
  - Ping (kiểm tra kết nối mạng)

- Thực hiện các kịch bản kiểm thử:
  - Truy cập hợp lệ và không hợp lệ giữa các vùng
  - Kiểm tra khả năng chặn và cho phép truy cập của firewall
  - Thu thập, phân tích và so sánh kết quả để đánh giá hiệu quả bảo mật của hệ thống

1.6. Ý nghĩa khoa học và thực tiễn

Về mặt khoa học, đề tài góp phần hệ thống hóa các kiến thức về bảo mật mạng và firewall, bao gồm các cơ chế như NAT, Port Filtering, Access Control List (ACL) và các chính sách kiểm soát truy cập. Đồng thời, việc triển khai firewall trong mô hình mạng doanh nghiệp giúp làm rõ nguyên lý hoạt động và vai trò của firewall trong việc bảo vệ hệ thống.

Về mặt thực tiễn, đề tài cung cấp mô hình triển khai firewall pfSense có thể áp dụng trong doanh nghiệp, đặc biệt là quy mô vừa và nhỏ. Kết quả thực nghiệm giúp minh họa hiệu quả của firewall trong việc kiểm soát truy cập và giảm thiểu rủi ro tấn công, đồng thời hỗ trợ nâng cao kỹ năng thiết kế và triển khai hệ thống mạng an toàn.

1.7. Bố cục báo cáo dự kiến:

Báo cáo được tổ chức thành 5 chương chính, đảm bảo trình bày đầy đủ từ cơ sở lý thuyết đến triển khai và đánh giá hệ thống như sau:

Chương 1: Tổng quan đề tài

Trình bày bối cảnh an toàn mạng trong doanh nghiệp, lý do lựa chọn đề tài, mục tiêu nghiên cứu, đối tượng và phạm vi nghiên cứu, phương pháp nghiên cứu, cũng như ý nghĩa khoa học và thực tiễn của đề tài.

Chương 2: Cơ sở lý thuyết

Trình bày các kiến thức nền tảng liên quan đến bảo mật mạng và firewall, bao gồm khái niệm, phân loại firewall, các cơ chế hoạt động như NAT, Port Filtering, Access Control List (ACL), cùng với các tiêu chí đánh giá hệ thống bảo mật.

Chương 3: Thiết kế hệ thống bảo mật mạng

Mô tả phương pháp thực hiện đề tài, bao gồm thiết kế mô hình mạng doanh nghiệp (WAN – LAN – DMZ), xây dựng môi trường thực nghiệm, triển khai firewall pfSense và cấu hình các chính sách bảo mật.

Chương 4: Triển khai thực nghiệm và đánh giá

Trình bày các kịch bản kiểm thử, kết quả thực nghiệm trước và sau khi triển khai firewall, đồng thời phân tích và so sánh hiệu quả của hệ thống dựa trên các chỉ số đánh giá.

Chương 5: Kết luận và hướng phát triển

Tổng kết các kết quả đạt được của đề tài, đánh giá những hạn chế còn tồn tại và đề xuất các hướng phát triển trong tương lai

CHƯƠNG 2: CƠ SỞ LÝ THUYẾT

2.1. Tổng quan về bảo mật mạng doanh nghiệp

Bảo mật mạng là tập hợp các giải pháp và cơ chế nhằm bảo vệ hệ thống khỏi truy cập trái phép, tấn công và rò rỉ dữ liệu. Trong doanh nghiệp, bảo mật mạng đảm bảo ba yếu tố cốt lõi: tính bảo mật (Confidentiality), tính toàn vẹn (Integrity) và tính sẵn sàng (Availability). Các mối đe dọa phổ biến hiện nay gồm quét cổng, brute-force, khai thác lỗ hổng và tấn công từ chối dịch vụ (DoS/DDoS). Theo OWASP Top 10 (2021)[1], các lỗ hổng bảo mật vẫn là nguyên nhân chính gây ra các cuộc tấn công.

Vì vậy, việc triển khai các giải pháp bảo mật phù hợp là cần thiết nhằm giảm thiểu rủi ro và đảm bảo hệ thống hoạt động an toàn, ổn định.

2.1.1. Kiến trúc mạng doanh nghiệp

Kiến trúc mạng doanh nghiệp thường được thiết kế theo mô hình phân tầng nhằm tối ưu hiệu năng, khả năng mở rộng và đảm bảo an toàn thông tin. Mô hình phổ biến gồm các vùng WAN, LAN và DMZ, mỗi vùng đảm nhận chức năng riêng trong hệ thống.

- WAN (Wide Area Network): Là mạng kết nối doanh nghiệp với Internet, tiềm ẩn nhiều nguy cơ tấn công từ bên ngoài.
- LAN (Local Area Network): Là mạng nội bộ của doanh nghiệp, nơi chứa các thiết bị và dữ liệu quan trọng.
- DMZ (Demilitarized Zone): Vùng trung gian dùng để đặt các máy chủ dịch vụ công cộng (Web, FTP, Email), giúp bảo vệ mạng nội bộ.
-

Trong kiến trúc này, firewall thường được triển khai tại các điểm giao tiếp giữa các vùng mạng để kiểm soát lưu lượng truy cập. Việc phân tách mạng thành nhiều vùng giúp giảm thiểu phạm vi ảnh hưởng khi xảy ra sự cố bảo mật và tăng cường khả năng kiểm soát hệ thống.

2.1.2. Mô hình phòng thủ nhiều lớp (Defense in Depth)

Mô hình phòng thủ nhiều lớp (Defense in Depth) là chiến lược bảo mật dựa trên việc triển khai nhiều lớp bảo vệ khác nhau nhằm tăng cường khả năng chống lại các cuộc tấn công. Thay vì phụ thuộc vào một cơ chế bảo mật duy nhất, mô hình này kết hợp nhiều giải pháp để tạo thành hệ thống bảo vệ toàn diện.

Các lớp bảo mật trong mô hình này có thể bao gồm:

- Lớp vật lý: Bảo vệ thiết bị phần cứng và hạ tầng mạng
- Lớp mạng: Sử dụng firewall, IDS/IPS để kiểm soát lưu lượng
- Lớp hệ thống: Bảo mật hệ điều hành và cấu hình máy chủ
- Lớp ứng dụng: Kiểm tra và bảo vệ các dịch vụ, phần mềm
- Lớp người dùng: Xác thực và phân quyền truy cập

Việc áp dụng mô hình Defense in Depth giúp giảm thiểu nguy cơ bị tấn công thành công, bởi ngay cả khi một lớp bảo mật bị vượt qua, các lớp khác vẫn tiếp tục bảo vệ hệ thống. Đây là một trong những nguyên tắc quan trọng trong thiết kế hệ thống bảo mật mạng doanh nghiệp hiện đại.

2.2. Firewall và các nguyên lý hoạt động

2.2.1. Phân loại Firewall

Firewall được chia thành các loại chính dựa trên cách thức xử lý và kiểm tra lưu lượng mạng:

- Packet Filtering Firewall: Là loại firewall cơ bản, hoạt động bằng cách kiểm tra các thông tin trong header của gói tin như:
  - Địa chỉ IP nguồn và đích
  - Cổng (port)
  - Giao thức (TCP/UDP)
  - Ưu điểm là tốc độ xử lý nhanh, nhưng hạn chế ở chỗ không kiểm tra nội dung bên trong gói tin nên mức độ bảo mật chưa cao.

- Stateful Firewall: Là firewall theo dõi trạng thái kết nối (session), chỉ cho phép các gói tin hợp lệ thuộc những kết nối đã được thiết lập trước đó.
  - Đây là loại firewall phổ biến hiện nay do cân bằng tốt giữa hiệu năng và bảo mật.

- Next-Generation Firewall (NGFW): Là thế hệ firewall nâng cao, tích hợp nhiều tính năng như:
  - Kiểm tra sâu gói tin (Deep Packet Inspection – DPI)
  - Phát hiện và ngăn chặn xâm nhập (IDS/IPS)
  - Lọc ứng dụng (Application Control)
  - NGFW có khả năng phát hiện các tấn công phức tạp ở tầng ứng dụng, mang lại mức độ bảo mật cao hơn so với các loại firewall truyền thống.

2.2.2. Cơ chế lọc gói và kiểm soát truy cập

Firewall hoạt động dựa trên tập hợp các luật (rules) để kiểm soát lưu lượng mạng. Khi một gói tin đi qua firewall, nó sẽ được kiểm tra lần lượt theo thứ tự các rule đã cấu hình.

Các hành động chính bao gồm:

- Allow: Cho phép gói tin đi qua
- Deny/Block: Từ chối gói tin
- Drop: Loại bỏ gói tin mà không phản hồi

Một nguyên tắc quan trọng trong cấu hình firewall là ***Default Deny:***

- Mặc định chặn toàn bộ lưu lượng
- Chỉ cho phép các kết nối được xác định là hợp lệ
- Cơ chế này giúp giảm thiểu rủi ro bảo mật bằng cách hạn chế tối đa các truy cập không cần thiết.

Ngoài ra, firewall còn hỗ trợ kiểm soát truy cập dựa trên:

- Địa chỉ IP
- Port
- Giao thức
- Thời gian truy cập
- Vùng mạng (LAN, WAN, DMZ)

2.2.3. NAT và quản lý kết nối

NAT (Network Address Translation) là cơ chế cho phép chuyển đổi địa chỉ IP giữa mạng nội bộ và mạng bên ngoài.

Các dạng NAT phổ biến gồm:

- Static NAT: Ánh xạ 1-1 giữa IP nội bộ và IP công khai
- Dynamic NAT: Ánh xạ linh hoạt từ pool IP
- PAT (Port Address Translation): Nhiều IP nội bộ dùng chung 1 IP công khai thông qua port

Vai trò của NAT:

- Che giấu cấu trúc mạng nội bộ
- Tiết kiệm địa chỉ IP công khai
- Tăng cường bảo mật

Bên cạnh đó, firewall còn thực hiện quản lý kết nối (connection tracking):

- Theo dõi trạng thái các phiên TCP/UDP
- Đảm bảo chỉ các gói tin hợp lệ trong phiên mới được phép đi qua
- Ngăn chặn các kết nối giả mạo hoặc bất thường

2.3. Tổng quan về pfSense

pfSense là hệ điều hành firewall mã nguồn mở dựa trên FreeBSD, được sử dụng phổ biến trong doanh nghiệp và môi trường lab. Hệ thống cung cấp các chức năng như firewall, NAT, VPN, VLAN và giám sát lưu lượng.

Với giao diện quản trị web thân thiện, pfSense cho phép cấu hình và quản lý mạng dễ dàng. Nhờ tính linh hoạt và khả năng mở rộng cao, đây là giải pháp hiệu quả để xây dựng hệ thống mạng an toàn.

2.3.1. Kiến trúc và thành phần

Hệ thống cho phép kiểm soát lưu lượng giữa các vùng mạng như WAN, LAN và DMZ, thường được triển khai trên máy chủ vật lý hoặc máy ảo.

Các thành phần chính của pfSense bao gồm:

- Kernel (FreeBSD): Là nền tảng hệ điều hành cung cấp khả năng xử lý mạng ổn định và bảo mật cao
- Packet Filter (pf): Là lõi firewall của pfSense, chịu trách nhiệm lọc và kiểm soát lưu lượng mạng
- WebGUI: Giao diện quản trị web giúp cấu hình hệ thống dễ dàng
- Subsystems: Bao gồm các module như NAT, DHCP, DNS Resolver, VPN…

pfSense hoạt động như một thiết bị trung gian (gateway), tất cả lưu lượng đi qua hệ thống đều được kiểm tra và xử lý dựa trên các rule đã cấu hình.

2.3.2. Các chức năng chính (Firewall, NAT, VPN, VLAN)

pfSense cung cấp nhiều chức năng mạnh mẽ phục vụ cho việc bảo mật và quản lý mạng: Firewall: Sử dụng lọc gói trạng thái (stateful), kiểm soát lưu lượng theo IP, port, protocol và trạng thái kết nối; hỗ trợ rule linh hoạt theo từng interface.

- NAT (Network Address Translation): Chuyển đổi IP giữa mạng nội bộ và bên ngoài; hỗ trợ Static, Dynamic và Port Forwarding, giúp ẩn hệ thống nội bộ và kiểm soát truy cập.

- VPN (Virtual Private Network): Hỗ trợ IPsec, OpenVPN, WireGuard, cho phép kết nối an toàn giữa các mạng hoặc người dùng từ xa.

- VLAN (Virtual LAN): Phân chia mạng vật lý thành nhiều mạng logic, tăng bảo mật và dễ quản lý.

Những chức năng này có thể kết hợp với nhau để xây dựng một hệ thống bảo mật toàn diện theo mô hình phân tầng.

2.3.3. Ưu điểm và hạn chế

Ưu điểm:

- Mã nguồn mở, miễn phí và có cộng đồng hỗ trợ lớn

- Giao diện WebGUI dễ sử dụng, phù hợp cho cả người mới và chuyên gia

- Hiệu năng ổn định khi triển khai trên phần cứng phù hợp

Hạn chế:

- Yêu cầu kiến thức mạng để cấu hình tối ưu và tránh sai sót

- Hiệu năng phụ thuộc vào tài nguyên phần cứng

2.4. Các mối đe dọa mạng phổ biến

Trong môi trường mạng hiện nay, hệ thống phải đối mặt với nhiều hình thức tấn công nhằm khai thác lỗ hổng và xâm nhập trái phép. Việc nhận diện các mối đe dọa phổ biến là cơ sở để xây dựng cơ chế phòng thủ và cấu hình firewall hiệu quả.

2.4.1. Tấn công quét cổng (Port Scanning)

Tấn công quét cổng là kỹ thuật được sử dụng để dò tìm các cổng (port) đang mở trên một hệ thống nhằm xác định các dịch vụ đang hoạt động.

- Kẻ tấn công sử dụng các công cụ như Nmap để:
  - Xác định các port mở (open)
  - Phát hiện dịch vụ đang chạy (HTTP, SSH, FTP,…)
  - Thu thập thông tin hệ thống

- Mục đích:
  - Tìm điểm yếu để khai thác
  - Chuẩn bị cho các cuộc tấn công tiếp theo

- Đặc điểm:
  - Không gây ảnh hưởng trực tiếp nhưng là bước trinh sát quan trọng
  - Khó phát hiện nếu không có hệ thống giám sát

- Firewall có thể giảm thiểu bằng cách:
  - Chặn các port không cần thiết
  - Ẩn thông tin hệ thống
  - Giới hạn số lượng request bất thường

2.4.2. Tấn công brute-force

Tấn công brute-force là phương pháp thử nhiều tổ hợp tài khoản và mật khẩu khác nhau để truy cập trái phép vào hệ thống.

- Thường nhắm vào các dịch vụ như:
  - SSH
  - FTP
  - Web login
- Cách thức hoạt động:
  - Tự động gửi hàng loạt yêu cầu đăng nhập
  - Sử dụng danh sách mật khẩu phổ biến hoặc từ điển
- Hậu quả:
  - Chiếm quyền truy cập hệ thống
  - Rò rỉ dữ liệu nhạy cảm

Biện pháp phòng chống:

- Giới hạn số lần đăng nhập sai
- Sử dụng xác thực nhiều lớp (MFA)
- Chặn IP có hành vi bất thường bằng firewall

2.4.3. Tấn công từ chối dịch vụ (DoS/DDoS)

Tấn công DoS (Denial of Service) và DDoS (Distributed Denial of Service) nhằm mục đích làm gián đoạn hoặc tê liệt hệ thống bằng cách gửi lượng lớn yêu cầu đến máy chủ.

- DoS: Tấn công từ một nguồn duy nhất
- DDoS: Tấn công từ nhiều nguồn (botnet), quy mô lớn hơn
- Cách thức hoạt động:
  - Flood traffic (TCP, UDP, HTTP request)
  - Làm cạn kiệt tài nguyên hệ thống (CPU, RAM, bandwidth)
- Hậu quả:
  - Dịch vụ không thể truy cập
  - Gián đoạn hoạt động kinh doanh

Firewall có thể hỗ trợ:

- Giới hạn tốc độ (rate limiting)
- Chặn IP bất thường
- Kết hợp với IDS/IPS để phát hiện tấn công

2.5. Tiêu chí đánh giá hệ thống bảo mật

Để đánh giá hiệu quả của hệ thống firewall, đề tài sử dụng các tiêu chí sau:

- Khả năng chặn truy cập trái phép
- Mức độ ẩn port (open, closed, filtered)
- Khả năng kiểm soát dịch vụ
- Hiệu quả ghi log và giám sát hệ thống

Các tiêu chí này giúp đánh giá toàn diện hiệu quả của firewall trong việc bảo vệ hệ thống mạng doanh nghiệp.

2.6. Kết luận chương

Trong chương này, đề tài đã trình bày tổng quan về firewall và các nguyên lý hoạt động cơ bản trong việc bảo vệ hệ thống mạng. Các nội dung chính bao gồm phân loại firewall, cơ chế lọc gói và kiểm soát truy cập, cũng như vai trò của NAT và quản lý kết nối trong việc đảm bảo an toàn thông tin.

Bên cạnh đó, chương cũng đã phân tích một số mối đe dọa mạng phổ biến như tấn công quét cổng (Port Scanning), tấn công brute-force và tấn công từ chối dịch vụ (DoS/DDoS). Đây là những hình thức tấn công thường gặp trong thực tế và có thể gây ảnh hưởng nghiêm trọng đến hệ thống nếu không được kiểm soát hiệu quả.

Thông qua việc tìm hiểu các nguyên lý hoạt động của firewall và các mối đe dọa mạng, chương này đã xây dựng nền tảng lý thuyết quan trọng cho việc thiết kế và triển khai hệ thống firewall trong các chương tiếp theo. Các kiến thức này sẽ được áp dụng vào mô hình thực nghiệm nhằm đánh giá khả năng bảo mật và hiệu quả hoạt động của hệ thống.

CHƯƠNG 3. THIẾT KẾ HỆ THỐNG BẢO MẬT MẠNG

3.1. Tổng quan mô hình đề xuất

Trong chương này, đề tài tập trung thiết kế một mô hình hệ thống mạng doanh nghiệp có tích hợp firewall nhằm nâng cao khả năng bảo mật và kiểm soát truy cập. Mô hình được xây dựng dựa trên kiến trúc phân vùng mạng gồm WAN, LAN và DMZ, trong đó firewall pfSense đóng vai trò trung tâm trong việc kiểm soát lưu lượng giữa các vùng.

Hệ thống được triển khai trong môi trường mô phỏng nhằm tái hiện các tình huống thực tế, từ đó phục vụ cho việc kiểm thử và đánh giá hiệu quả của các cơ chế bảo mật.

3.2. Thiết kế kiến trúc mạng

3.2.1. Phân vùng mạng (WAN, LAN, DMZ)

Hệ thống mạng được chia thành ba vùng chính:

- WAN (Wide Area Network): Kết nối với Internet, là khu vực có nguy cơ bị tấn công cao nhất.

- LAN (Local Area Network): Mạng nội bộ doanh nghiệp, chứa các thiết bị người dùng và dữ liệu quan trọng.

- DMZ (Demilitarized Zone): Vùng trung gian, nơi các dịch vụ công khai như Web Server nhằm giảm thiểu rủi ro truy cập trực tiếp vào mạng nội bộ.

Việc phân vùng này giúp kiểm soát lưu lượng hiệu quả và hạn chế phạm vi ảnh hưởng khi xảy ra tấn công.

3.2.2. Sơ đồ kiến trúc hệ thống

Mô hình hệ thống được thiết kế với firewall pfSense nằm giữa các vùng mạng, đóng vai trò như một gateway trung tâm. Các kết nối giữa WAN – LAN – DMZ đều phải đi qua firewall để được kiểm soát.

Internet

|

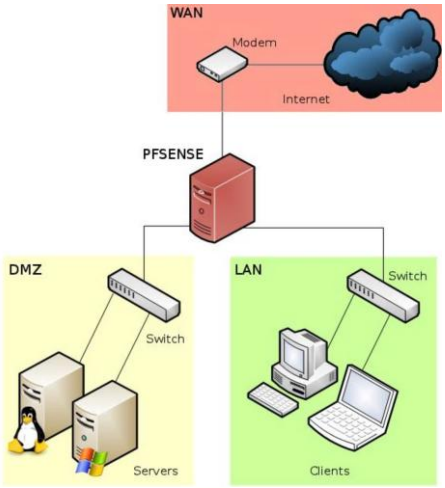
[Firewall]

/ \

DMZ LAN

| |

Web Server User PC



Trong đó:

- DMZ: chứa các dịch vụ công khai (Web Server)
- LAN: mạng nội bộ người dùng
- Firewall: kiểm soát toàn bộ lưu lượng giữa các vùng

3.3. Thiết kế hệ thống firewall pfSense

3.3.1. Cài đặt và cấu hình cơ bản

Firewall pfSense được cài đặt trên môi trường máy ảo (VMware). Sau khi cài đặt, hệ thống được cấu hình các interface tương ứng với WAN, LAN và DMZ.

Các bước cấu hình cơ bản bao gồm:

- Gán địa chỉ IP cho từng interface
- Thiết lập gateway
- Cấu hình DNS
- Kiểm tra kết nối giữa các vùng mạng

3.3.2. Thiết lập rule firewall

Các rule firewall được thiết lập nhằm kiểm soát lưu lượng giữa các vùng mạng theo nguyên tắc ***Default Deny***

.

Cụ thể:

- Cho phép LAN truy cập Internet
- Chặn truy cập trực tiếp từ WAN vào LAN
- Chỉ cho phép truy cập từ WAN vào DMZ thông qua các port dịch vụ cần thiết
- Cho phép truy cập từ WAN đến Web Server trong DMZ thông qua các port dịch vụ cần thiết như HTTP (80) và HTTPS (443).

Các rule được sắp xếp theo thứ tự ưu tiên nhằm đảm bảo hiệu quả kiểm soát.

3.3.3. Cấu hình NAT và Port Forwarding

NAT được sử dụng để chuyển đổi địa chỉ IP nội bộ sang IP công cộng khi truy cập Internet.

Port Forwarding được cấu hình để:

- Cho phép truy cập từ bên ngoài vào Web Server trong DMZ
- Chỉ mở các port cần thiết (ví dụ: 80)
- Tăng cường bảo mật bằng cách hạn chế dịch vụ công khai

3.4. Triển khai các cơ chế bảo mật

3.4.1. Kiểm soát truy cập

Hệ thống sử dụng các rule firewall, NAT và chính sách kiểm soát truy cập để quản lý lưu lượng giữa các vùng WAN, LAN và DMZ. Chỉ các kết nối hợp lệ và dịch vụ cần thiết mới được phép thông qua firewall nhằm giảm thiểu nguy cơ truy cập trái phép vào hệ thống nội bộ.

3.4.2. Phân đoạn mạng (Network Segmentation)

Việc phân đoạn mạng giúp cô lập các khu vực quan trọng, giảm thiểu rủi ro lây lan khi xảy ra sự cố bảo mật.

DMZ đóng vai trò như lớp đệm giữa Internet và mạng nội bộ, giúp bảo vệ hệ thống LAN.

3.5. Xây dựng chính sách bảo mật

Chính sách bảo mật được xây dựng dựa trên nguyên tắc:

- Default Deny
- Chỉ mở các dịch vụ cần thiết
- Giám sát và ghi log hệ thống
- Phân quyền truy cập rõ ràng

Chính sách bảo mật mẫu:

Port	Dịch Vụ	Trạng Thái
80	HTTP	Allow(DMZ only)
22	SSH	Allow (LAN → DMZ only)
23	Telnet	Block
All	Other Services	Deny

Các chính sách này giúp kiểm soát lưu lượng mạng, hạn chế truy cập trái phép và tăng cường khả năng bảo vệ hệ thống nội bộ.

3.6. Kết luận chương

Chương 3 đã trình bày chi tiết quá trình thiết kế hệ thống bảo mật mạng doanh nghiệp sử dụng firewall pfSense. Từ việc xây dựng mô hình mạng, cấu hình firewall đến triển khai các cơ chế bảo mật và chính sách kiểm soát truy cập, hệ thống đã được thiết kế theo hướng tối ưu và phù hợp với thực tế.

Những nội dung trong chương này là cơ sở để tiến hành triển khai thực nghiệm và đánh giá hiệu quả của hệ thống trong chương tiếp theo.

CHƯƠNG 4. TRIỂN KHAI THỰC NGHIỆM VÀ ĐÁNH GIÁ

4.1. Môi trường thực nghiệm

4.1.1. Hạ tầng ảo hóa (VMware/VirtualBox)

Danh sách các máy ảo:

Hệ thống thực nghiệm sử dụng 4 máy ảo trên VMware gồm: pfSense (firewall trung tâm), Kali Linux (attacker), Web Server đặt trong DMZ và Client trong LAN. Các thành phần này mô phỏng mô hình WAN – DMZ – LAN và phục vụ cho việc kiểm thử, đánh giá hiệu quả của firewall.



Hình 4.1: Danh sách các máy ảo

Virtual Network (VMnet):

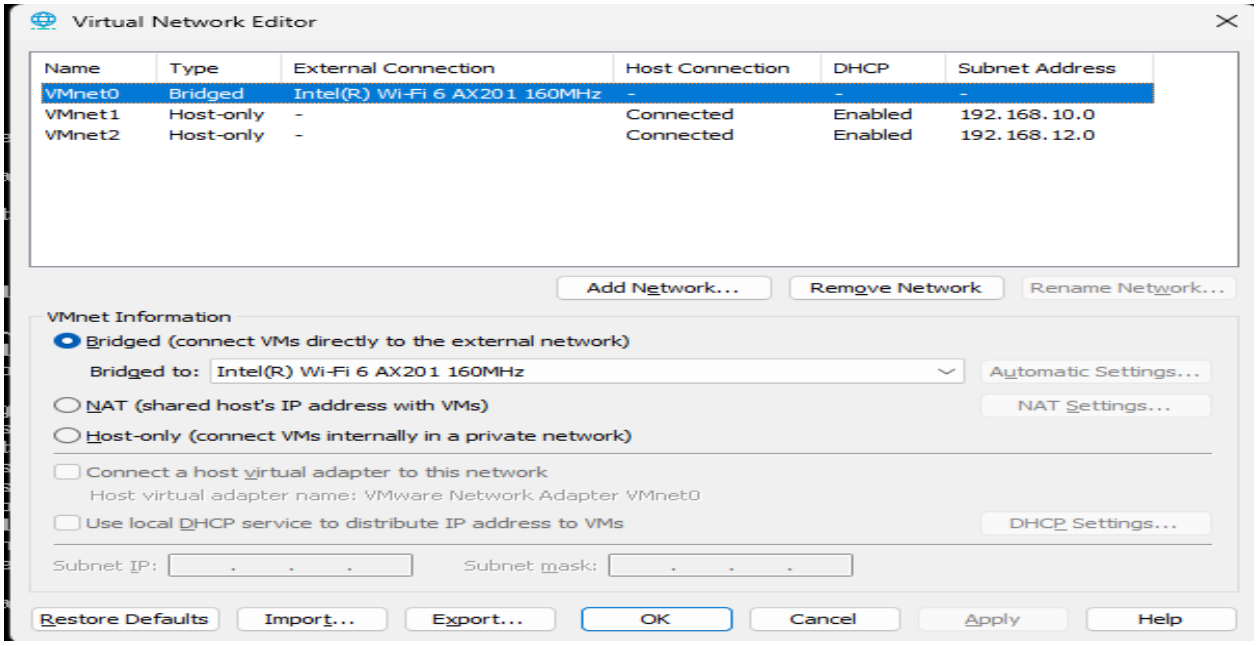
Hệ thống sử dụng các mạng ảo (Virtual Network – VMnet) trong VMware để mô phỏng các vùng mạng khác nhau trong mô hình doanh nghiệp. Cụ thể:

– VMnet0 (WAN): được cấu hình ở chế độ Bridged, kết nối trực tiếp với mạng vật lý, đóng vai trò mô phỏng Internet.

– VMnet1 (LAN): được cấu hình ở chế độ Host-only, sử dụng dải địa chỉ 192.168.10.0/24, đại diện cho mạng nội bộ người dùng.

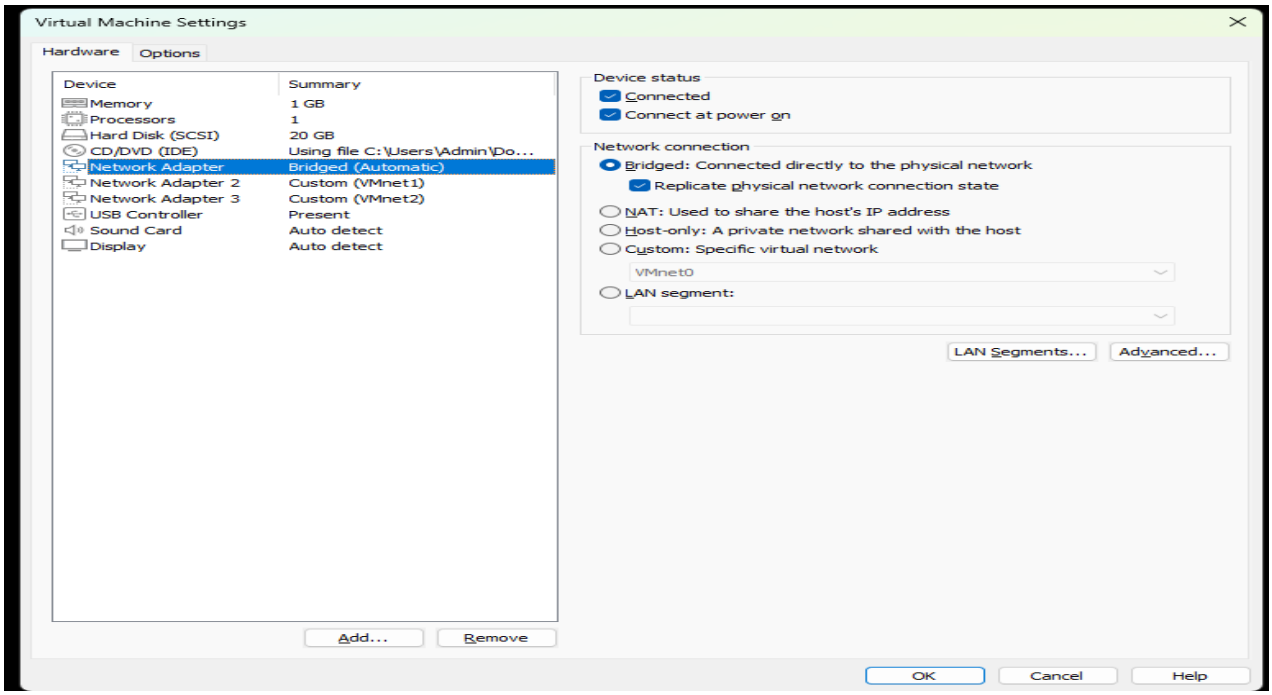
– VMnet2 (DMZ): được cấu hình ở chế độ Host-only, sử dụng dải địa chỉ 192.168.12.0/24, dùng để triển khai các dịch vụ công khai như Web Server.

Việc phân tách các mạng ảo này giúp đảm bảo các vùng WAN, LAN và DMZ hoạt động độc lập, đồng thời cho phép firewall pfSense kiểm soát lưu lượng giữa các vùng mạng một cách hiệu quả.



Hình 4.2: Cấu hình các mạng ảo VMnet trong VMware

Adapter pfSense (3 card):



Hình 4.3: Cấu hình card mạng pfSense trong VMware

pfSense được cấu hình với 3 card mạng, trong đó Adapter 1 (WAN) kết nối dạng Bridged để mô phỏng Internet, Adapter 2 (LAN) và Adapter 3 (DMZ) được kết nối tới các mạng ảo VMnet1 và VMnet2 nhằm phân tách các vùng mạng.

4.1.2. Cấu hình hệ thống

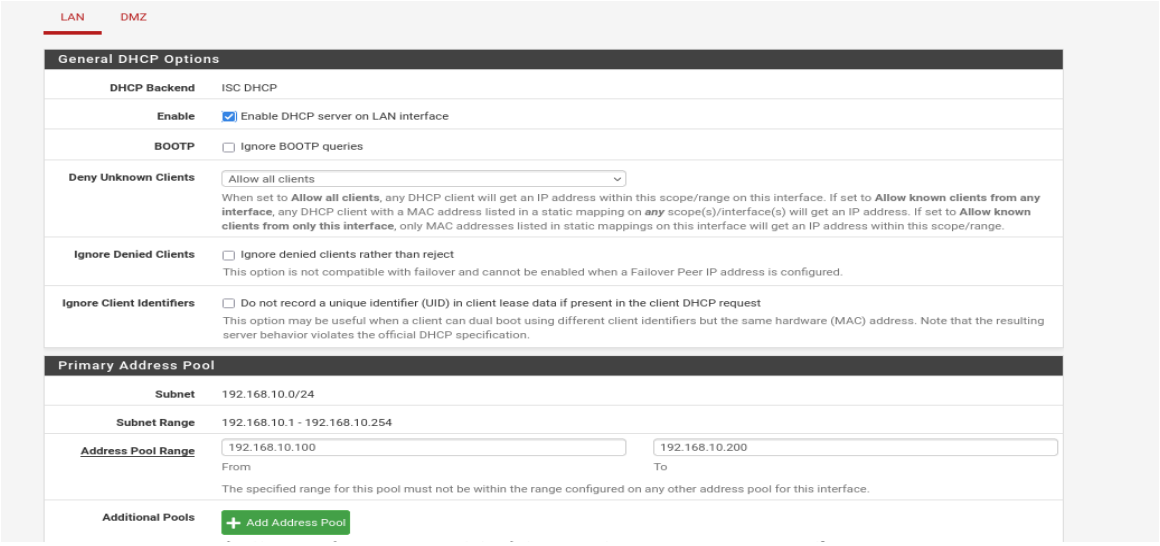
- Interface pfSense:



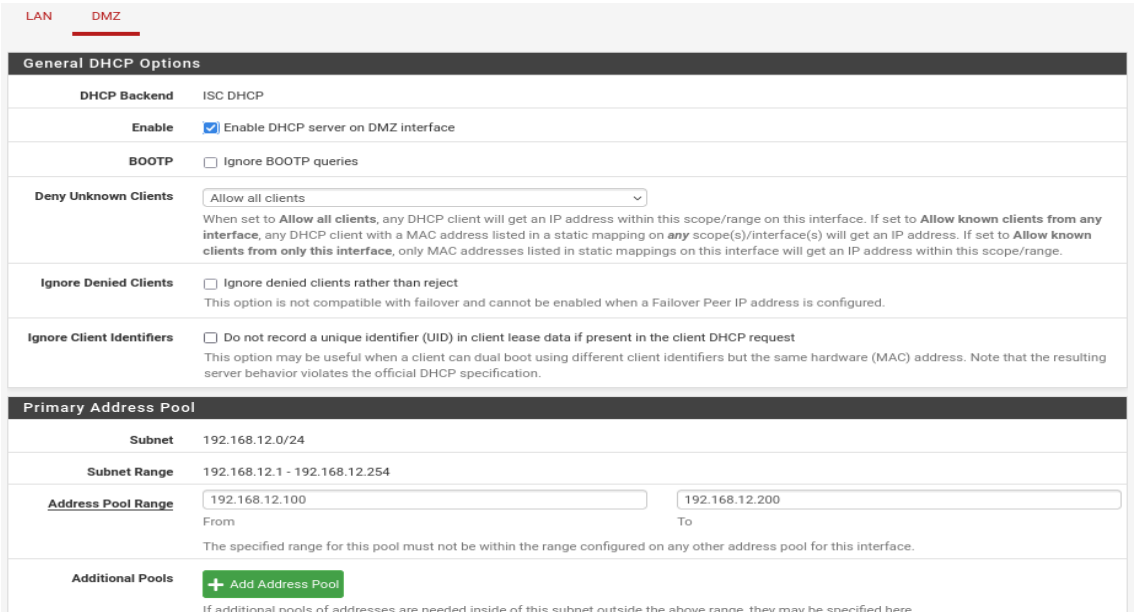
Hình 4.4: Cấu hình các interface WAN, LAN và DMZ trên pfSense

pfSense được cấu hình với ba interface tương ứng với các vùng WAN, LAN và DMZ. WAN nhận địa chỉ IP động từ mạng ngoài, trong khi LAN và DMZ sử dụng các dải địa chỉ riêng để làm gateway cho các mạng nội bộ.

- Cấu hình DHCP Server:



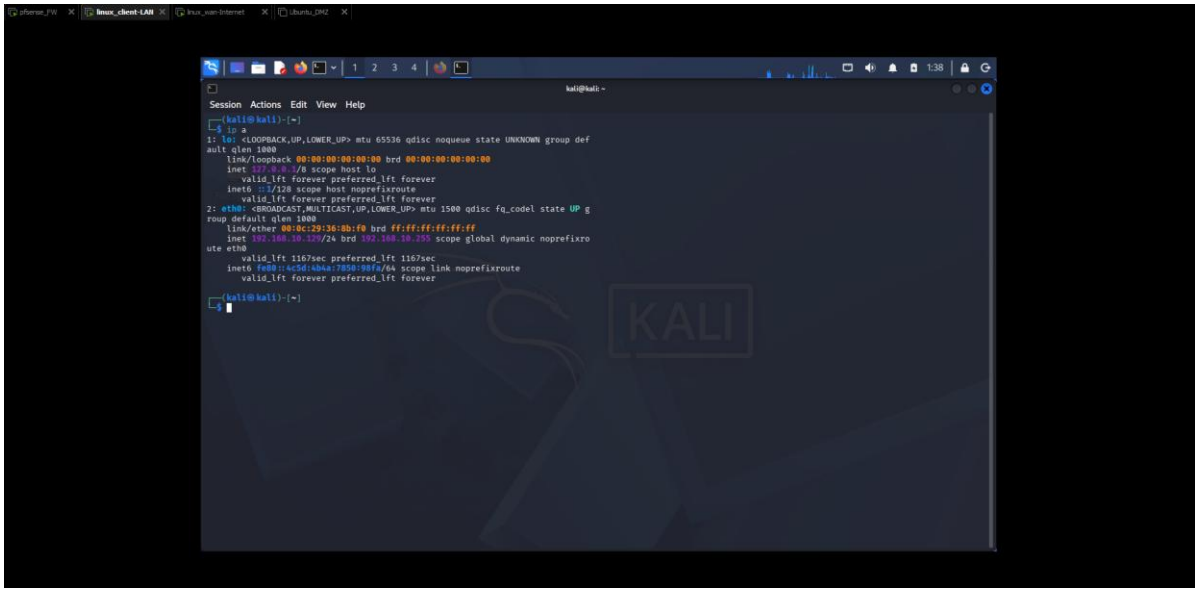
Hình 4.5: Cấu hình DHCP Server cho mạng LAN trên pfSense



Hình 4.6: Cấu hình DHCP Server cho mạng DMZ trên pfSense

DHCP Server được cấu hình trên pfSense cho cả hai mạng LAN và DMZ nhằm tự động cấp địa chỉ IP cho các thiết bị trong hệ thống. Cụ thể, mạng **LAN** sử dụng dải địa chỉ từ **192.168.10.100 - 192.168.10.200 (192.168.10.0/24)** và mạng **DMZ** sử dụng dải địa chỉ từ **192.168.12.100 - 192.168.12.200 (192.168.12.0/24).** Việc phân chia dải IP giúp quản lý hiệu quả và tránh xung đột địa chỉ trong hệ thống.

- Địa chỉ IP của Client (LAN):



Hình 4.7: Địa chỉ IP của máy Client trong mạng LAN

Client trong LAN đã nhận địa chỉ IP 192.168.10.129 từ DHCP Server, chứng minh hệ thống mạng hoạt động ổn định.

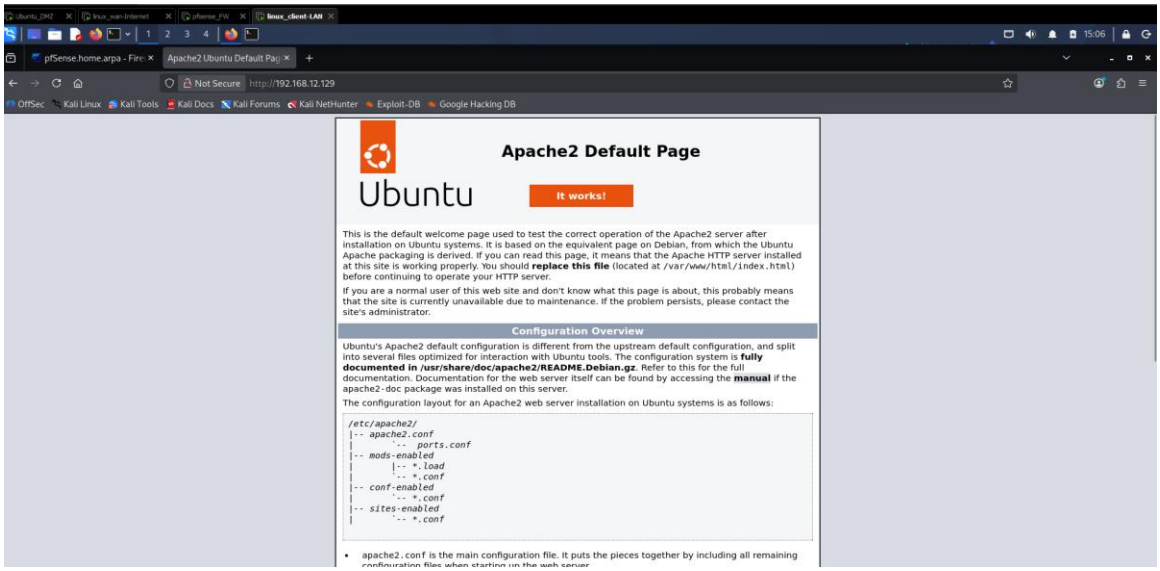
- Địa chỉ IP của Server (DMZ)

```
dmz@webserver:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
       valid_lft forever preferred_lft forever
2: ens33: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 00:0c:29:62:fd:36 brd ff:ff:ff:ff:ff:ff
    altname enp2s1
    inet 192.168.12.129/24 metric 100 brd 192.168.12.255 scope global dynamic ens33
       valid_lft 1640sec preferred_lft 1640sec
    inet6 fe80::20c:29ff:fe62:fd36/64 scope link
       valid_lft forever preferred_lft forever
dmz@webserver:~$ _
```

Hình 4.8: Địa chỉ IP của Web Server trong vùng DMZ

Web Server trong DMZ đã nhận địa chỉ IP 192.168.12.129 từ DHCP Server, chứng minh hệ thống mạng hoạt động ổn định.

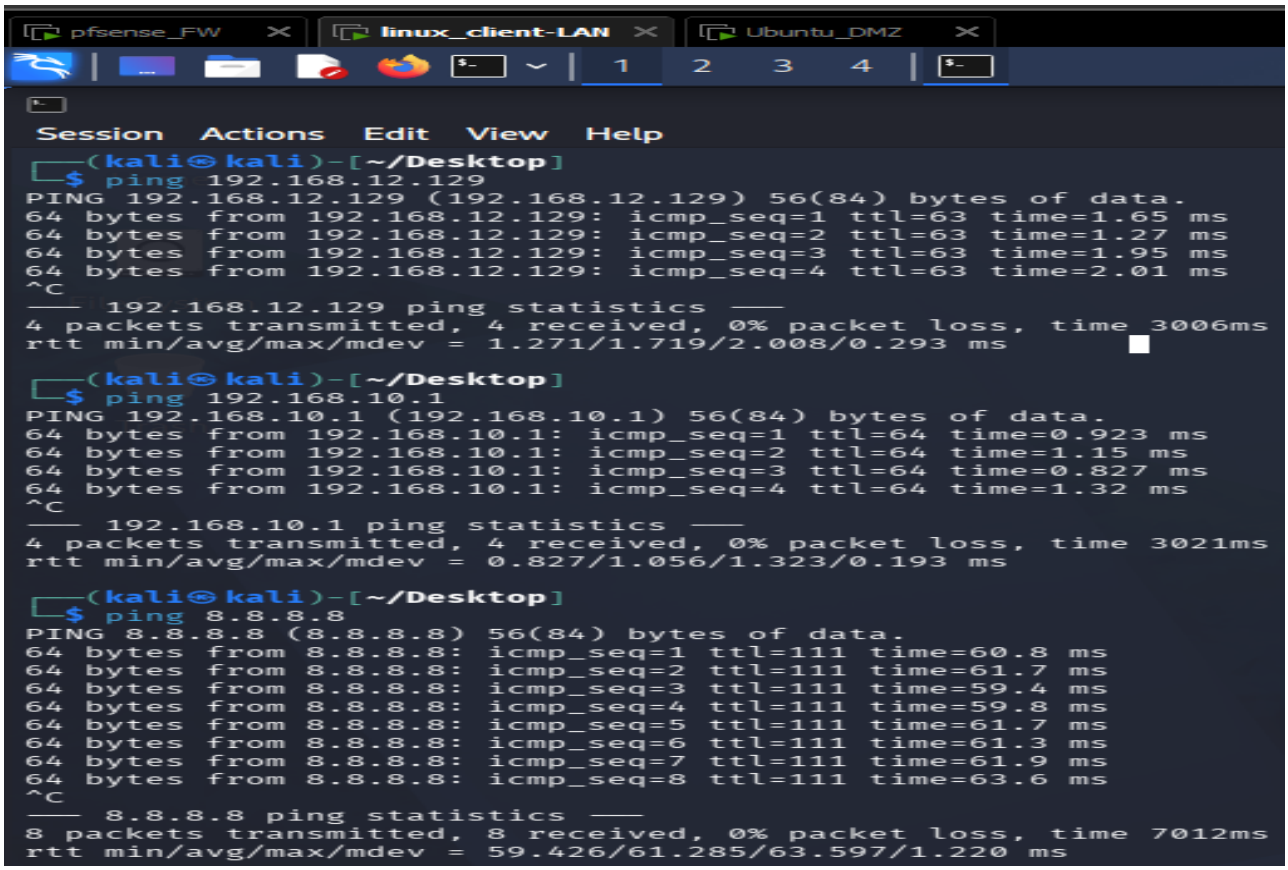
- Web Server hoạt động:



Hình 4.9: Kiểm tra truy cập Web Server trong vùng DMZ từ trình duyệt

Web Server trong vùng DMZ hoạt động bình thường, trang mặc định của Apache2 được hiển thị khi truy cập từ trình duyệt.

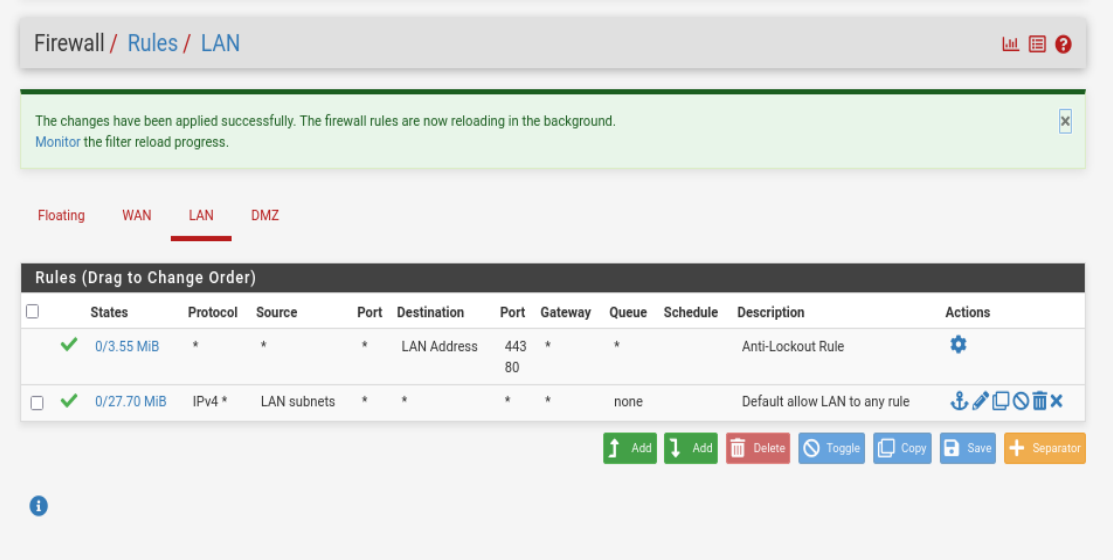
- Kiểm tra kết nối mạng



Hình 4.10: Kiểm tra kết nối mạng từ máy client trong LAN

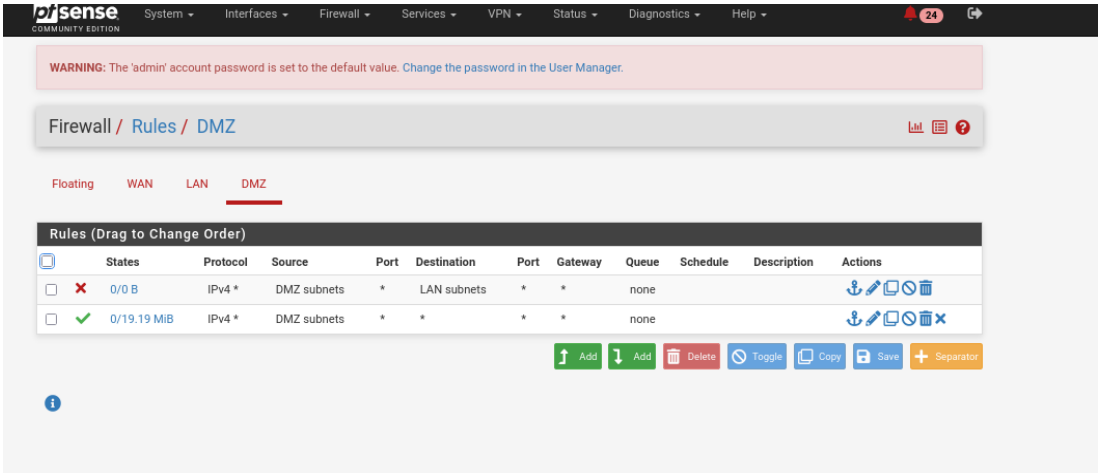
Máy client trong LAN ping thành công đến Web Server DMZ (192.168.12.129), gateway (192.168.10.1) và Internet (8.8.8.8), cho thấy hệ thống mạng hoạt động ổn định và cấu hình định tuyến.

- Cấu hình Firewall Rules:



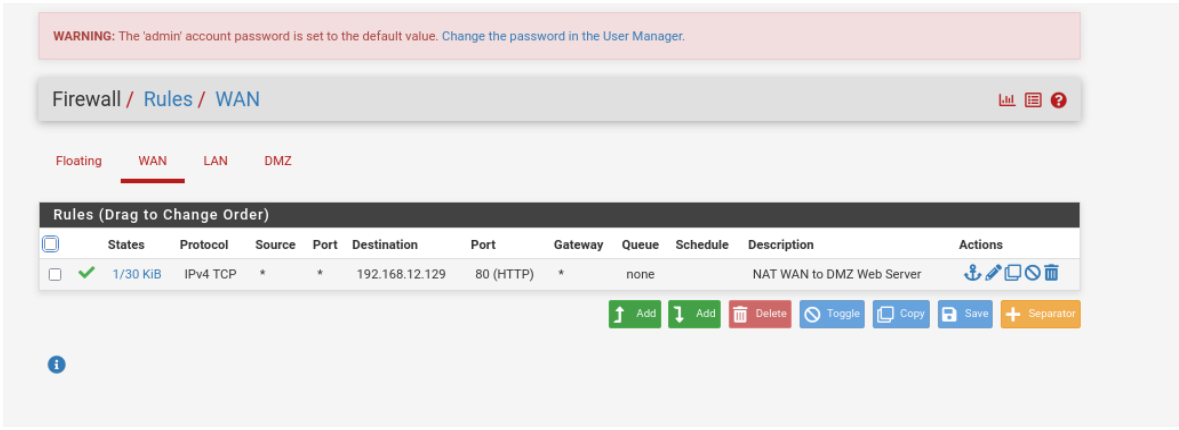
Hình 4.11: Cấu hình rule firewall cho mạng LAN trên pfSense

Firewall được cấu hình cho phép các máy trong mạng LAN truy cập đến các mạng khác và Internet thông qua rule mặc định.



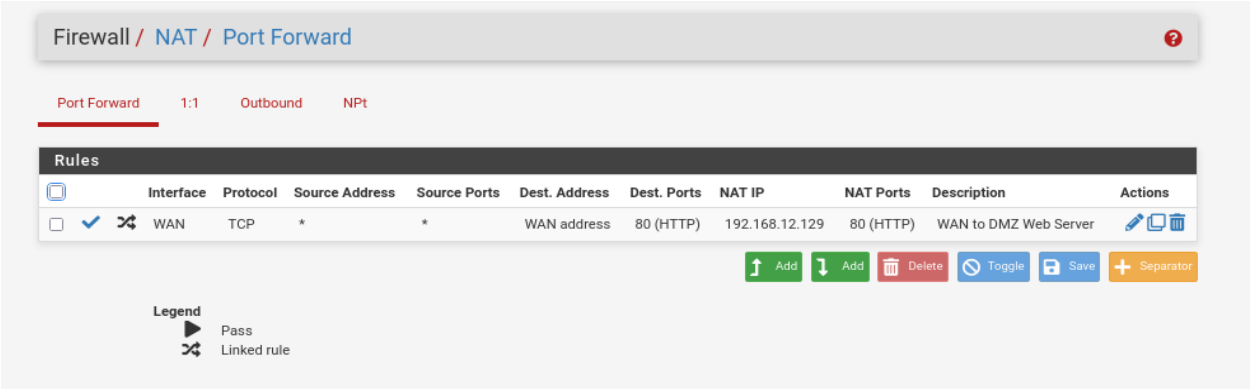
Hình 4.12: Cấu hình rule firewall cho mạng DMZ trên pfSense

Firewall được cấu hình để chặn truy cập từ mạng DMZ vào mạng LAN nhằm bảo vệ hệ thống nội bộ. Đồng thời, các máy trong DMZ vẫn được phép truy cập ra ngoài để phục vụ các dịch vụ cần thiết. Điều này đảm bảo nếu Web Server trong DMZ bị tấn công, kẻ tấn công không thể truy cập vào mạng nội bộ.

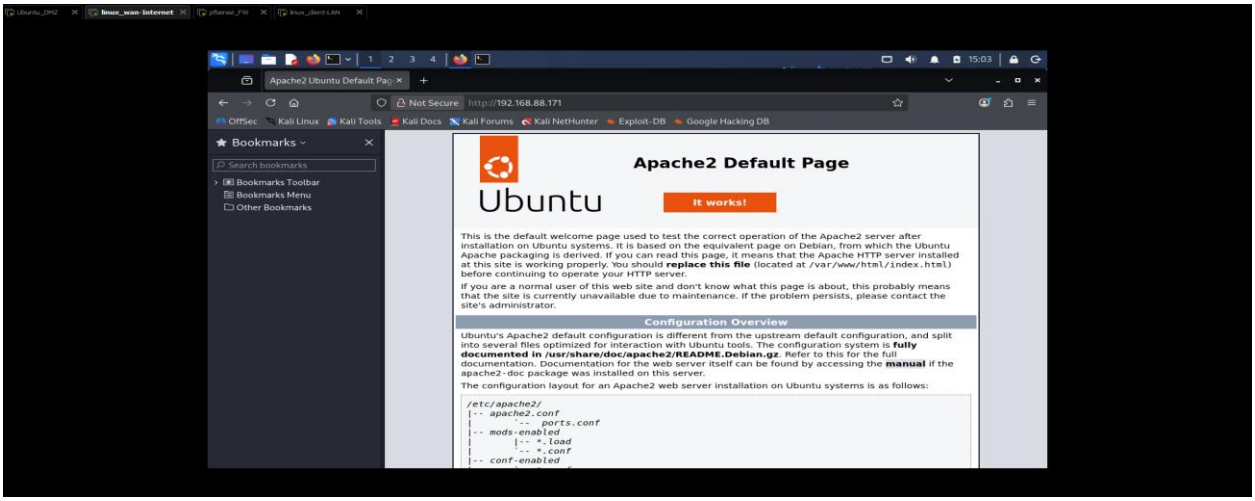


Hình 4.13: Rule WAN cho phép truy cập Web Server DMZ qua HTTP (80).

Firewall sử dụng NAT Port Forward để cho phép truy cập Web Server DMZ qua HTTP (80) và ngăn truy cập trực tiếp vào mạng nội bộ.



Hình 4.14: Cấu hình NAT Port Forward trên pfSense chuyển tiếp lưu lượng HTTP từ WAN đến Web Server trong DMZ.



Hình 4.15: Kết quả truy cập thành công Web Server DMZ từ mạng WAN.

4.2. Kịch bản tấn công mô phỏng

Hệ thống được kiểm thử với 2 kịch bản tấn công, thực hiện trong hai trường hợp:

- Tấn công từ mạng nội bộ (LAN → DMZ)
- Tấn công từ bên ngoài (WAN → DMZ/LAN)

4.2.1. Quét cổng (Nmap)

- **Trường hợp 1:** Internal Attack (LAN → DMZ): Attacker từ mạng LAN sử dụng Nmap để quét Web Server trong vùng DMZ nhằm phát hiện các cổng mở và dịch vụ đang hoạt động.

- **Trường hợp 2:** External Attack (WAN → DMZ): Attacker từ bên ngoài thực hiện quét cổng vào Web Server DMZ nhằm kiểm tra các dịch vụ đang được công khai ra Internet.

4.2.2. Brute-force SSH

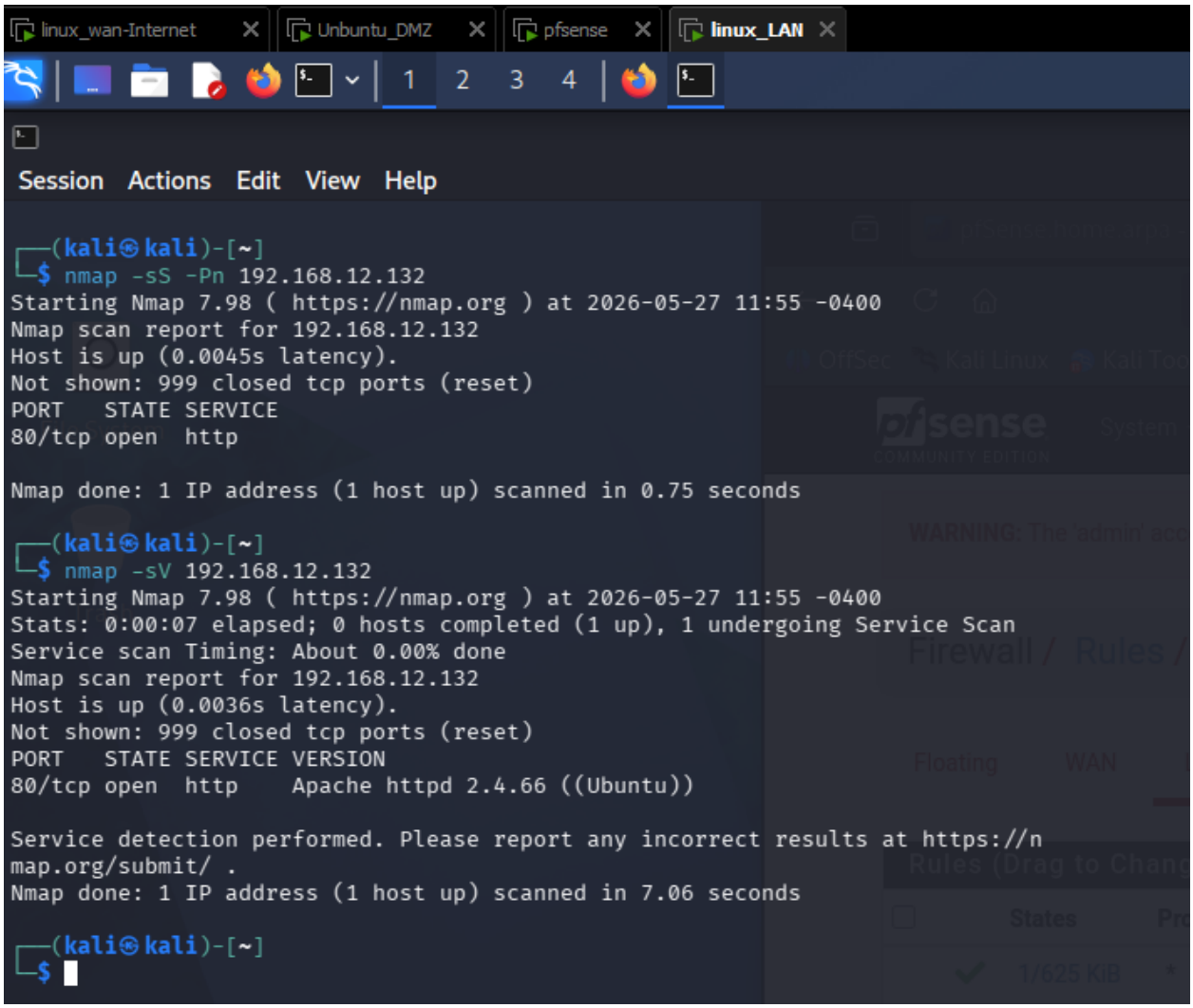
- **Trường hợp 1:** Internal Attack (LAN → DMZ): Attacker từ mạng LAN thực hiện brute-force vào dịch vụ SSH trên Web Server DMZ nhằm thử đăng nhập trái phép.

- **Trường hợp 2:** External Attack (WAN → DMZ): Attacker từ mạng WAN thử thực hiện brute-force vào dịch vụ SSH của hệ thống thông qua địa chỉ WAN của pfSense. Tuy nhiên, dịch vụ SSH không được công khai qua firewall nên kết nối bị từ chối.

4.3. Kết quả kiểm thử trước khi triển khai IDS/IPS trên pfSense

4.3.1. Kết quả quét cổng (Port Scanning)

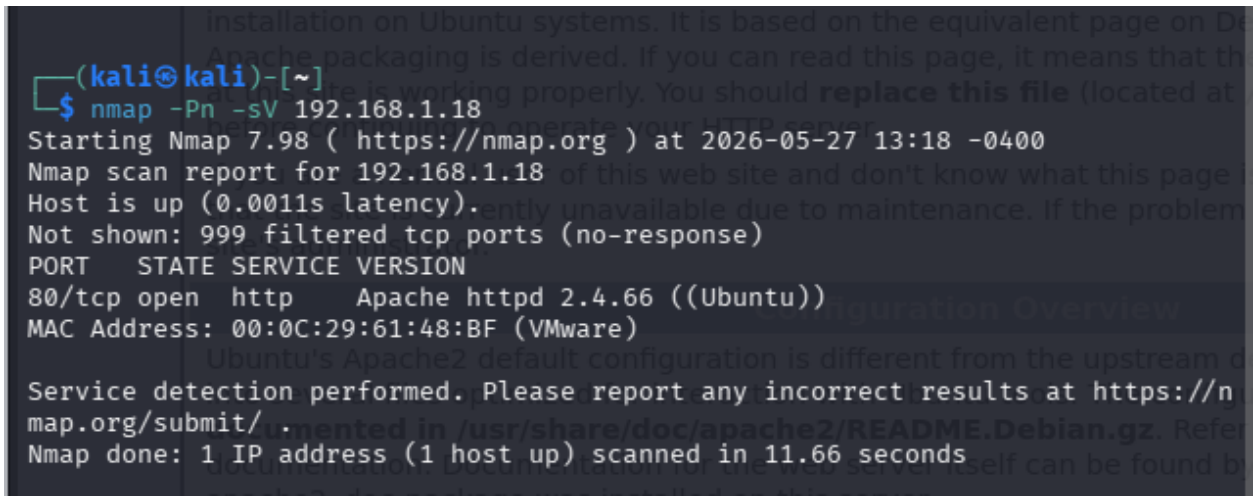
- Internal Attack (LAN → DMZ):



Hình 4.16: Kết quả quét cổng Web Server từ LAN trước khi kích hoạt Snort

Kết quả cho thấy port 80 đang mở và dịch vụ Apache HTTP Server 2.4.66 đang hoạt động, chứng tỏ attacker có thể trinh sát và thu thập thông tin hệ thống thành công.

- External Attack (WAN → DMZ):



Hình 4.17: Kết quả quét cổng Web Server từ WAN trước khi kích hoạt Snort

Trước khi kích hoạt Snort IDS/IPS trên WAN, attacker từ bên ngoài quét cổng vào địa chỉ WAN của pfSense (192.168.1.18). Kết quả cho thấy cổng 80 mở và dịch vụ Apache HTTP Server trên Web Server DMZ bị phát hiện, chứng tỏ hệ thống công khai có thể bị attacker thu thập thông tin.

4.3.2. Kết quả brute-force SSH

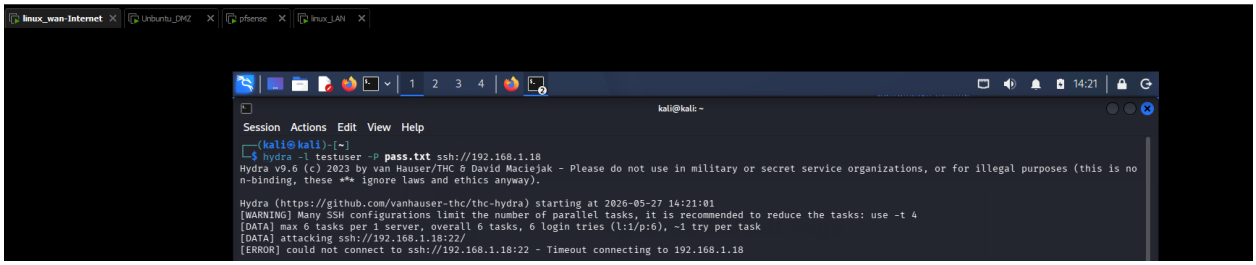
- Internal Attack (LAN → DMZ):



Hình 4.18: Attacker từ mạng LAN thực hiện brute-force thành công vào dịch vụ SSH của Web Server DMZ bằng công cụ Hydra.

Trước khi triển khai IDS/IPS, attacker từ mạng nội bộ dùng Hydra brute-force SSH vào Web Server DMZ và dò thành công tài khoản testuser/123456, cho thấy hệ thống dùng thông tin xác thực yếu.

- External Attack (WAN → DMZ):



Hình 4.19: Kết quả thử brute-force SSH từ mạng WAN thất bại do firewall không cho phép truy cập dịch vụ SSH vào vùng DMZ.

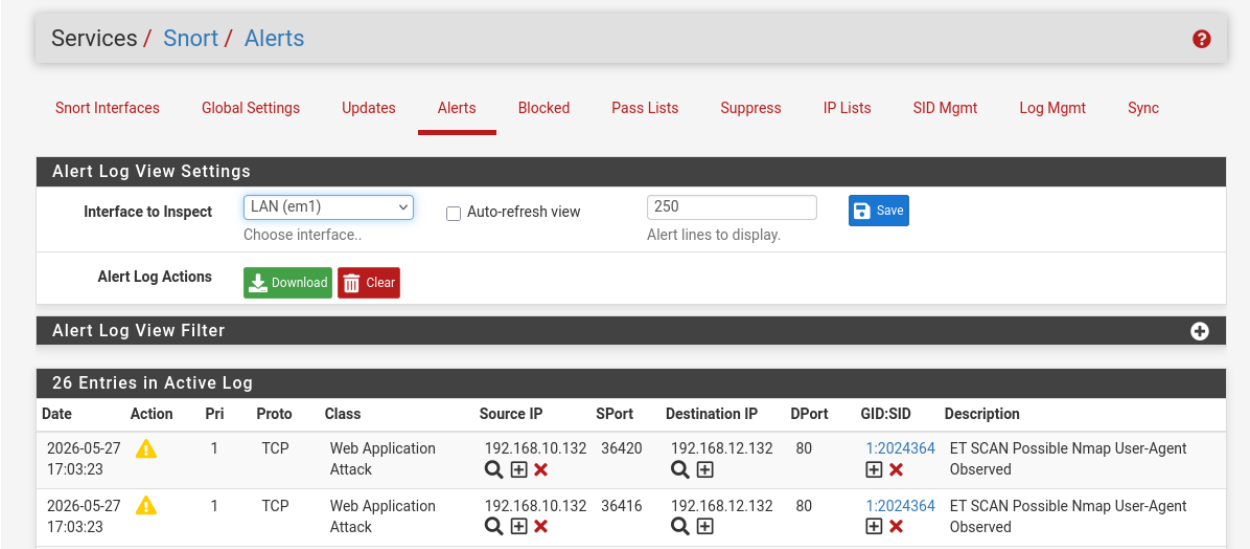
Attacker từ mạng WAN sử dụng công cụ Hydra để thử brute-force vào dịch vụ SSH của Web Server DMZ thông qua địa chỉ WAN của pfSense. Tuy nhiên, do firewall chỉ công khai dịch vụ HTTP (cổng 80) và không cho phép truy cập SSH (cổng 22), kết nối bị từ chối, ngăn chặn tấn công ngay từ lớp firewall.

4.4. Kết quả kiểm thử sau khi kích hoạt IDS/IPS trên pfSense

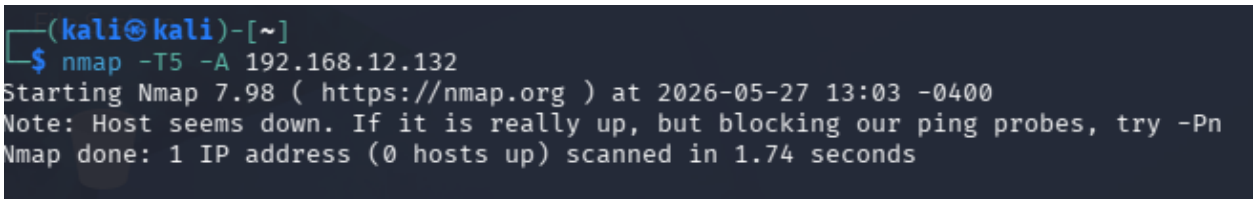
Trong quá trình thực nghiệm, hệ thống sử dụng Snort để giám sát và phát hiện quét cổng, đồng thời sử dụng Suricata để kiểm thử khả năng phát hiện các lưu lượng bất thường liên quan đến brute-force SSH.

4.4.1. Kết quả quét cổng (Port Scanning) sau khi triển khai Snort IDS/IPS

- Internal Attack (LAN → DMZ):

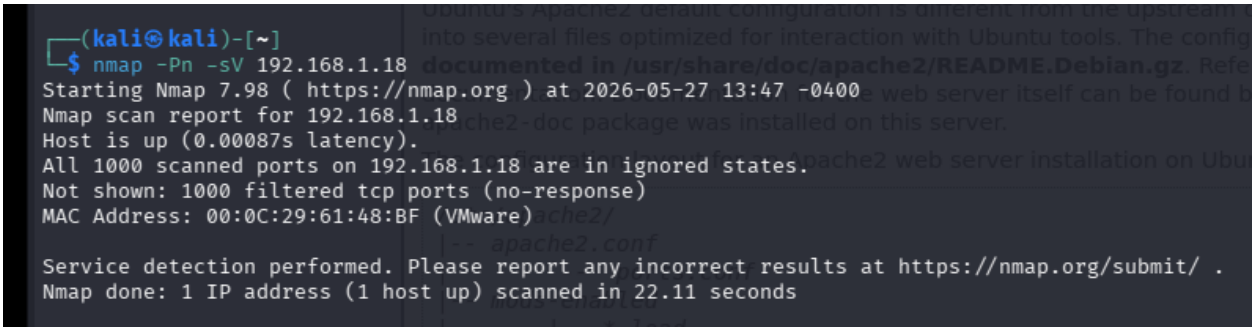


Hình 4.20: Snort phát hiện hành vi quét cổng từ attacker trong mạng LAN



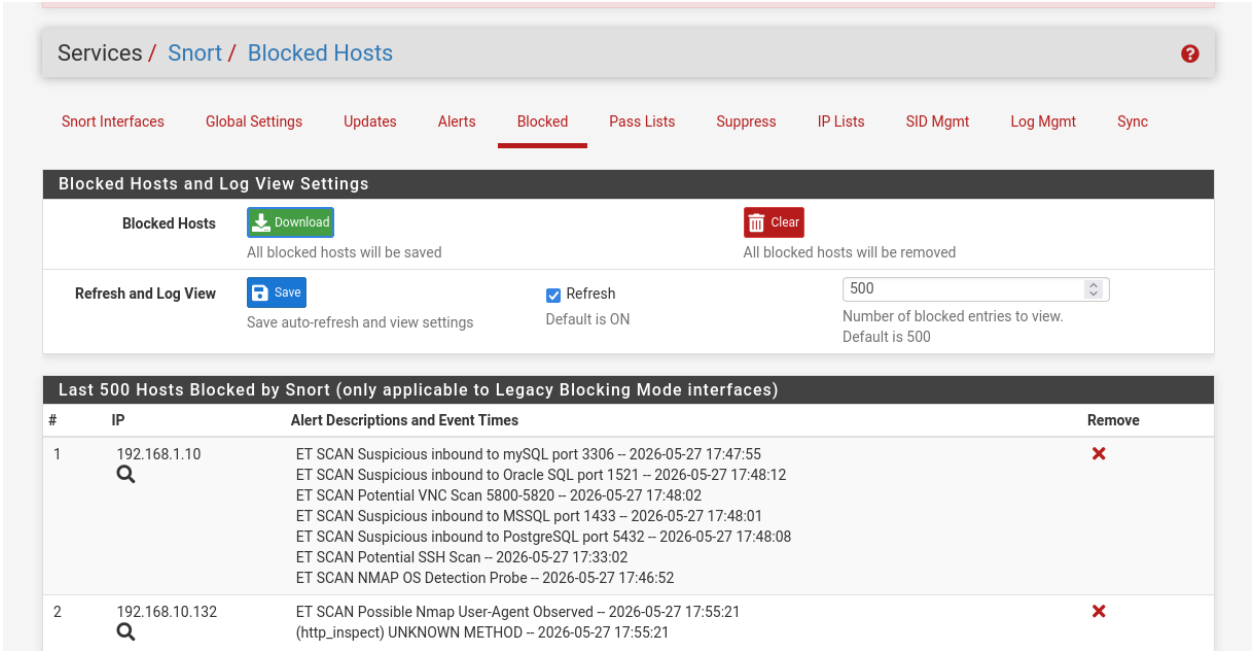
Hình 4.21: Attacker không thể tiếp tục quét cổng sau khi bị hệ thống chặn

- External Attack (WAN → DMZ):



Hình 4.22: Kết quả quét cổng từ WAN sau khi hệ thống phát hiện và chặn attacker bằng Snort IDS/IPS.

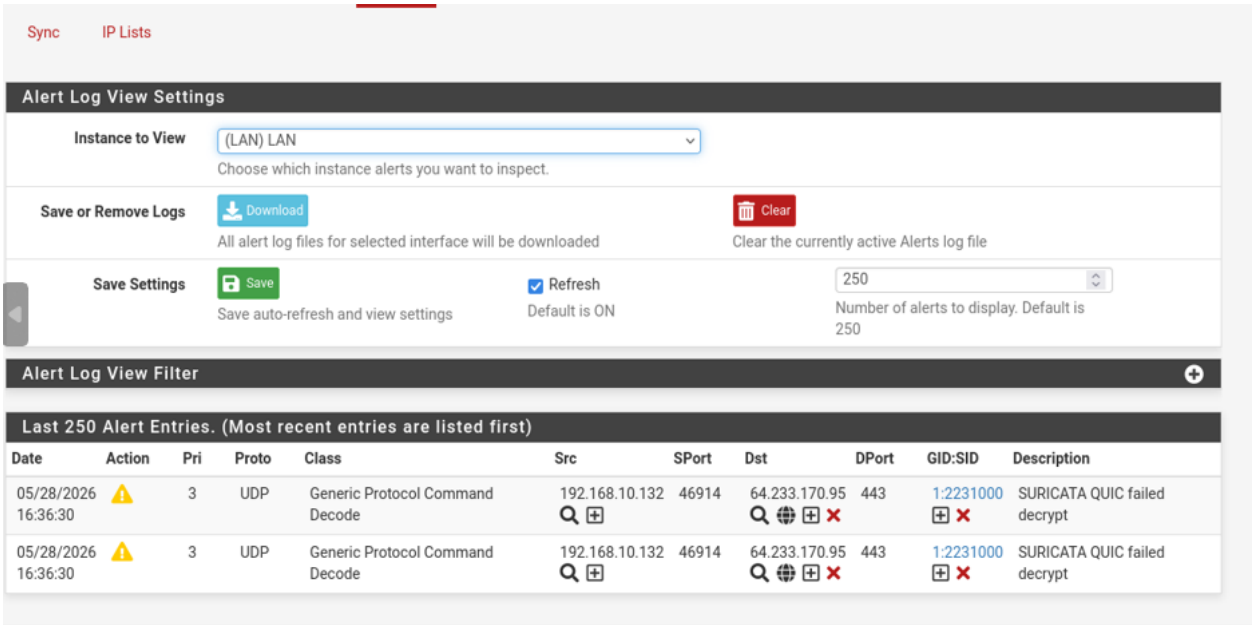
- Kết quả:



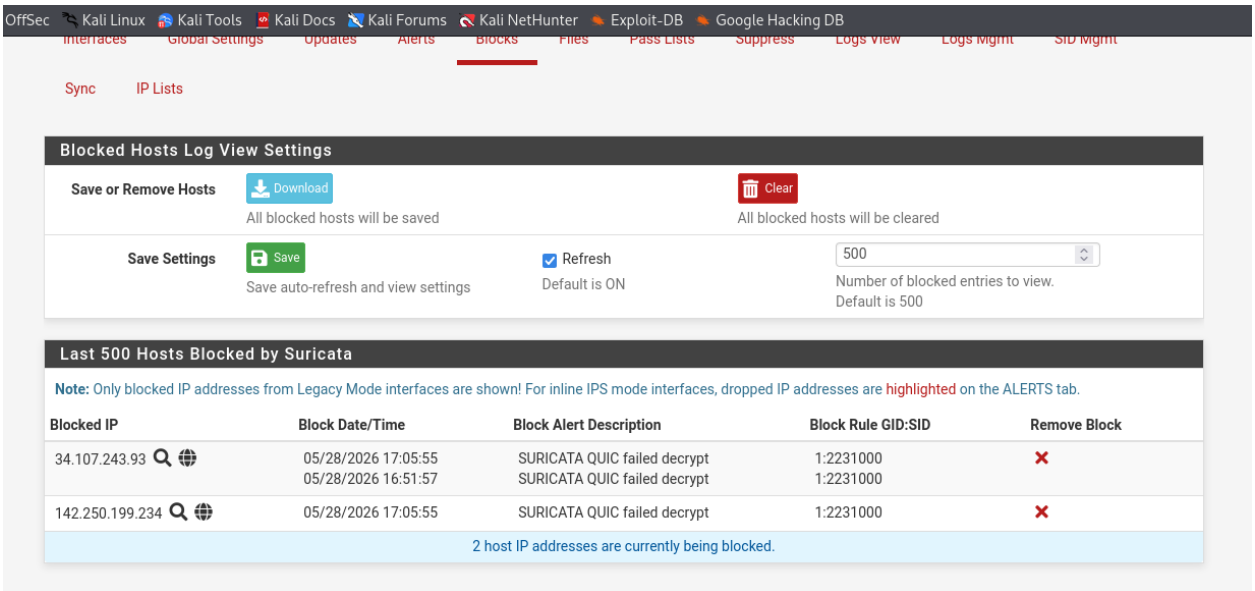
Hình 4.23: pfSense tự động thêm địa chỉ IP nguồn tấn công vào danh sách chặn sau khi Snort IDS/IPS phát hiện hành vi quét cổng bất thường.

4.4.2. Kết quả brute-force SSH sau khi triển khai Suricata

- Internal Attack (LAN → DMZ):



Hình 4.24: Suricata IDS/IPS phát hiện lưu lượng SSH brute-force bất thường từ attacker và sinh cảnh báo trên pfSense.



Hình 4.25: Sau khi phát hiện nhiều yêu cầu đăng nhập SSH bất thường, Suricata tự động chặn địa chỉ IP nguồn nhằm ngăn brute-force tiếp tục.

- External Attack (WAN → DMZ):

Dịch vụ SSH không được công khai từ WAN vào DMZ theo chính sách firewall, do đó attacker từ Internet không thể thiết lập kết nối để thực hiện brute-force. Điều này giúp giảm bề mặt tấn công và ngăn chặn tấn công ngay từ lớp perimeter security.

4.4.3. Bảng so sánh kết quả trước và sau khi kích hoạt IDS/IPS

Kịch bản	**Trước khi triển khai IDS/IPS**	**Sau khi triển khai IDS/IPS**
Quét cổng từ LAN → DMZ	Attacker sử dụng Nmap phát hiện port 80 và dịch vụ Apache đang hoạt động trên Web Server DMZ	Snort IDS/IPS phát hiện hành vi quét cổng và tự động chặn IP attacker
Quét cổng từ WAN → DMZ	Attacker từ WAN phát hiện Web Server công khai qua cổng HTTP/80	Snort IDS/IPS phát hiện scan bất thường và đưa IP attacker vào danh sách chặn
Brute-force SSH từ LAN → DMZ	Hydra brute-force thành công tài khoản SSH do sử dụng mật khẩu yếu	Suricata IDS/IPS phát hiện lưu lượng bất thường và sinh cảnh báo trong quá trình brute-force SSH
Brute-force SSH từ WAN → DMZ	Attacker không thể truy cập SSH do firewall không NAT cổng 22	Firewall tiếp tục chặn truy cập SSH từ WAN, giảm nguy cơ brute-force từ Internet

4.5. Đánh giá hiệu quả hệ thống

4.5.1. Khả năng phát hiện và ngăn chặn

Hệ thống firewall kết hợp Snort và Suricata IDS/IPS cho thấy khả năng phát hiện và hỗ trợ ngăn chặn hiệu quả các hành vi quét cổng và brute-force SSH.

4.5.2. Tính ổn định hệ thống

Trong quá trình thực nghiệm, hệ thống hoạt động ổn định, các dịch vụ trong DMZ vẫn hoạt động bình thường khi firewall và Snort được kích hoạt.

4.5.3. Ảnh hưởng đến hiệu năng mạng

Việc kích hoạt Snort IDS/IPS làm tăng mức sử dụng tài nguyên hệ thống nhưng không ảnh hưởng đáng kể đến hoạt động của mô hình thực nghiệm.

4.6. Thảo luận kết quả

Kết quả thực nghiệm cho thấy mô hình firewall pfSense hoạt động đúng với kiến trúc WAN – LAN – DMZ đã thiết kế. Firewall giúp kiểm soát lưu lượng mạng hiệu quả, cho phép các dịch vụ hợp lệ hoạt động đồng thời ngăn chặn các truy cập trái phép vào mạng nội bộ.

Cơ chế NAT Port Forward cho phép người dùng từ WAN truy cập Web Server trong vùng DMZ thông qua dịch vụ HTTP (80), trong khi các dịch vụ nhạy cảm như SSH không được công khai ra Internet nhằm giảm bề mặt tấn công của hệ thống.

Bên cạnh đó, việc triển khai Snort IDS/IPS giúp phát hiện và hỗ trợ ngăn chặn các hành vi quét cổng bất thường trong quá trình kiểm thử. Đồng thời, Suricata IDS/IPS hỗ trợ giám sát và sinh cảnh báo đối với các lưu lượng đáng ngờ liên quan đến brute-force SSH trong mạng nội bộ.

Kết quả thực nghiệm cho thấy việc kết hợp firewall pfSense với các cơ chế IDS/IPS đã góp phần nâng cao khả năng giám sát, phát hiện và giảm thiểu nguy cơ tấn công đối với hệ thống mạng doanh nghiệp.

4.7. Kết luận chương

Qua quá trình thực nghiệm, hệ thống firewall pfSense theo mô hình WAN – LAN – DMZ đã hoạt động đúng với thiết kế đề ra. Firewall giúp kiểm soát lưu lượng mạng, cho phép các dịch vụ hợp lệ hoạt động và hạn chế truy cập trái phép vào hệ thống nội bộ.

Ngoài ra, cơ chế NAT Port Forward cho phép truy cập Web Server trong vùng DMZ qua HTTP (80), trong khi Snort và Suricata IDS/IPS hỗ trợ phát hiện và giám sát các hành vi quét cổng và brute-force SSH trong quá trình kiểm thử.

Kết quả cho thấy hệ thống hoạt động ổn định và đáp ứng mục tiêu xây dựng mô hình firewall kết hợp IDS/IPS nhằm nâng cao khả năng bảo mật mạng doanh nghiệp cơ bản.

CHƯƠNG 5. KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN

5.1. Kết luận

Đề tài đã xây dựng thành công mô hình firewall pfSense theo kiến trúc WAN – LAN – DMZ trong môi trường ảo hóa VMware. Hệ thống cho phép kiểm soát lưu lượng mạng, phân tách vùng mạng và bảo vệ hệ thống nội bộ trước các truy cập trái phép.

Ngoài ra, việc triển khai NAT Port Forward giúp công khai Web Server trong vùng DMZ qua HTTP (80), đồng thời Snort và Suricata IDS/IPS hỗ trợ phát hiện và ngăn chặn các hành vi tấn công như quét cổng và brute-force trong quá trình thực nghiệm.

5.2. Đóng góp của đề tài

- Xây dựng mô hình mạng WAN – LAN – DMZ bằng pfSense.
- Cấu hình firewall rule và NAT Port Forward cho hệ thống.
- Triển khai Web Server trong vùng DMZ.
- Thực hiện mô phỏng các kịch bản tấn công từ WAN và LAN.
- Tích hợp Snort và Suricata IDS/IPS để giám sát và hỗ trợ ngăn chặn tấn công.

5.3. Hạn chế

- Mô hình thực nghiệm còn đơn giản và triển khai trong môi trường ảo hóa.
- Chưa triển khai các cơ chế bảo mật nâng cao như VPN hoặc cân bằng tải.
- Mô hình chưa triển khai trong môi trường thực tế với lưu lượng lớn nên chưa đánh giá được khả năng chịu tải của IDS/IPS.
- Số lượng kịch bản tấn công và rule IDS/IPS còn hạn chế.

5.4. Hướng phát triển trong tương lai

- Mở rộng mô hình với nhiều dịch vụ và vùng mạng hơn.
- Nghiên cứu triển khai VPN và hệ thống giám sát tập trung.
- Tối ưu rule firewall và IDS/IPS để tăng hiệu quả bảo mật.
- Thử nghiệm thêm các kịch bản tấn công nâng cao trong môi trường thực tế.

Tài Liệu Tham Khảo

[1] OWASP Top 10, 2021

[2] Netgate, pfSense Documentation

[3] William Stallings, Network Security Essentials